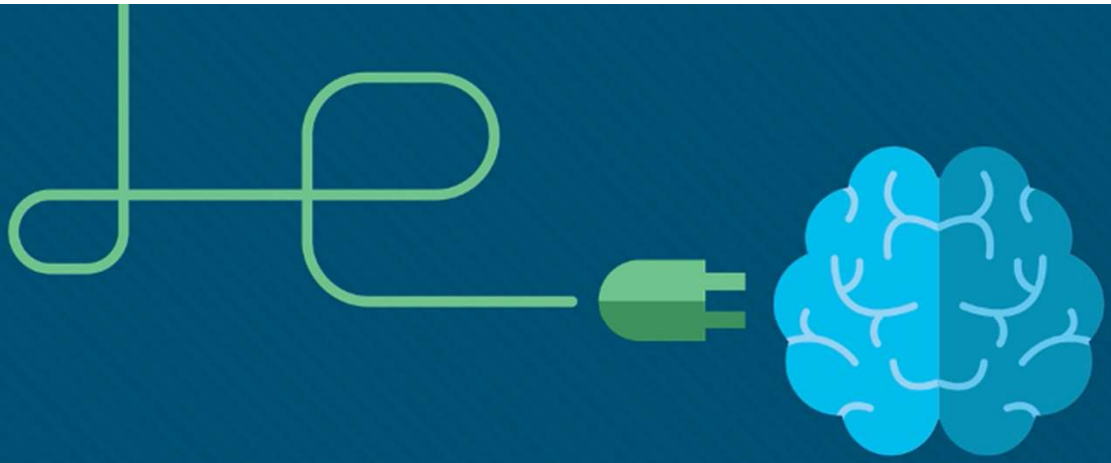


Módulo 1: Introdução à Cibersegurança



Introdução à Cibersegurança

Objetivos do Módulo

Título do Módulo: Introdução à Cibersegurança

Objetivo do Módulo: Explicar o básico de manter a segurança online, incluindo o que é cibersegurança e seu impacto potencial.

Título do Tópico	Objetivo do Tópico
O mundo da segurança cibernética	Explicar o que é segurança cibernética e o possível impacto.
Dados organizacionais	Identificar os tipos de informações confidenciais que os hackers podem usar para invadir a privacidade e/ou prejudicar a reputação, onde podem acessar essas informações e por que elas são interessantes para os criminosos cibernéticos.
O que foi roubado?	Explicar o que são dados corporativos e por que devem ser protegidos.
Invasores cibernéticos	Descrever quem são os invasores cibernéticos e o que eles querem.
Guerra cibernética	Explicar o que é guerra cibernética e o motivo pelo qual as nações e os governos precisam de profissionais de segurança cibernética para ajudá-los a proteger os cidadãos e a infraestrutura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.1 O Mundo da Cibersegurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O que é a Cibersegurança?

- A cibersegurança é o esforço contínuo para proteger indivíduos, organizações e governos contra ataques digitais, protegendo sistemas em rede e dados contra uso não autorizado ou danos.

- **Pessoal:** Em um nível pessoal, você precisa proteger sua identidade, seus dados e seus dispositivos de computação.

- **Organizacional:** Em nível organizacional, é responsabilidade de todos proteger a reputação da organização, seus dados e clientes.

- **Governo**: À medida que mais informações digitais são coletadas e compartilhadas, sua proteção se torna ainda mais vital no nível governamental, onde a segurança nacional, a estabilidade econômica e a segurança e bem-estar dos cidadãos estão em jogo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protegendo seu Dados Pessoais

- Os dados pessoais são quaisquer informações que possam ser usadas para identificá-lo e que possam existir tanto offline quanto online.

- **Identidade off-line**
  - É a persona da vida real que você apresenta diariamente em casa, na escola ou no trabalho.
  - Como resultado, a família e os amigos sabem detalhes sobre sua vida pessoal, incluindo seu nome completo, idade e endereço.
  - É importante não esquecer a importância de proteger sua identidade offline.
  - Quando você não está olhando, os ladrões de identidade podem roubar seus dados com facilidade!

- **Identidade on-line**
  - Não é apenas um nome, é quem você é e como se apresenta aos outros online.
  - Inclui o nome de usuário ou apelido que você usa para suas contas online, bem como a identidade social que você estabelece e retrata em comunidades e sites online.
  - Você deve tomar cuidado para limitar a quantidade de informações pessoais que revela por meio da sua identidade online.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Seus Dados

- Dados pessoais descrevem qualquer informação sobre você (nome, número de seguro social, número da carteira de motorista, data e local de nascimento, nome de solteira da sua mãe, fotos ou mensagens trocadas com outros).
- Cibercriminosos podem usar essas informações sensíveis para identificar e se passar por você, infringindo sua privacidade e potencialmente causando danos sérios à sua reputação.

Os hackers podem colocar as mãos nos seus dados pessoais por meio de registros, incluindo:

Registros médicos	Toda vez que você visita o médico, informações pessoais relacionadas à sua saúde física e mental e bem-estar são adicionadas aos seus registros eletrônicos de saúde (EHRs). Como a maioria desses registros são salvos on-line, você precisa estar ciente das informações médicas que compartilha. E esses registros vão além dos limites do consultório médico.
Registros de educação	Os registros educacionais contêm informações sobre suas qualificações acadêmicas e realizações. Isso também pode incluir suas informações de contato, registros de presença, relatórios disciplinares, registros de saúde e imunização, bem como quaisquer registros de educação especial, incluindo programas de educação individualizados (IEPs).
Registros de empregos e financeiros	Dados de emprego podem ser valiosos para hackers se eles conseguirem informações sobre seus empregos anteriores - ou até mesmo suas avaliações de desempenho atuais. Seus registros financeiros podem incluir informações sobre sua renda e despesas. Seus registros fiscais podem incluir contracheques, extratos de cartão de crédito, sua pontuação de crédito e detalhes da sua conta bancária.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Onde Estão os Meus Dados?

Imagine que ontem você compartilhou algumas fotos do seu primeiro dia de trabalho com alguns de seus amigos próximos.Mas isso deve estar OK, certo? Vamos ver...

- Você tirou algumas fotos no trabalho usando seu telefone celular.
- Cópias dessas fotos estão disponíveis no seu dispositivo móvel.
- Você os compartilhou com cinco amigos próximos, que moram em vários locais do mundo.
- Todos os seus amigos baixaram as fotos e agora têm cópias delas nos dispositivos.
- Um de seus amigos ficou tão orgulhoso que decidiu publicar e compartilhar suas fotos on-line.
- As fotos não estão mais apenas no seu dispositivo.
- Elas acabaram, na verdade, em servidores localizados em diferentes partes do mundo e pessoas que você nem conhece agora têm acesso às suas fotos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O que mais?

- Este é apenas um exemplo que nos lembra que toda vez que coletamos ou compartilhamos dados pessoais, devemos considerar nossa segurança.
- Existem diferentes leis que protegem a privacidade e os dados no seu país.
- Você sabe onde estão seus dados?
  - Após uma consulta, o médico atualizará seu prontuário médico.
    - Para fins de faturamento, essas informações podem ser compartilhadas com a seguradora.
    - Nesses casos, seu prontuário médico, ou parte dele, agora pode ser acessado pela seguradora.
  - Cartões de fidelidade de lojas podem ser uma maneira conveniente de economizar dinheiro em suas compras.
    - No entanto, a loja está usando este cartão para criar um perfil do seu comportamento de compra, que pode ser usado para direcioná-lo com ofertas especiais de seus parceiros de marketing.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dispositivos Inteligentes

- Considere a frequência com que você usa seus dispositivos de computação para acessar seus dados pessoais.
- A menos que tenha optado por receber extratos em papel, você provavelmente acessa cópias digitais de extratos de conta bancária no site do seu banco.
- E ao pagar uma conta, é muito provável que você tenha transferido os fundos necessários por meio de um aplicativo bancário no telefone celular.
- Além de permitir acessar suas informações, os dispositivos de computação também podem gerar informações sobre você.
- Tecnologias vestíveis, como smartwatches e rastreadores de atividade, coletam seus dados para pesquisa clínica, monitoramento da saúde do paciente e rastreamento de condicionamento físico e bem-estar.
- À medida que o mercado global de rastreadores de fitness cresce, também aumenta o risco para seus dados pessoais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Roubo de Identidade

- Não contentes em roubar seu dinheiro para obter ganhos financeiros de curto prazo, os criminosos digitais investem no ganho de longo prazo do roubo de identidade.

Furto de dados médicos

- O aumento dos custos médicos levou a um aumento no roubo de identidade médica, com criminosos digitais roubando seguros médicos para usar os benefícios para si mesmos.
- Onde isso acontecer, todos os procedimentos médicos realizados em seu nome serão salvos em seus registros médicos.

Atividade bancária

- Roubar dados privados pode ajudar cibercriminosos a acessar contas bancárias, cartões de crédito, perfis sociais e outras contas online.
- Armado com essa informação, um ladrão de identidade poderia apresentar uma declaração de imposto falsa e receber o reembolso.
- Eles podem até contrair empréstimos em seu nome e arruinar sua classificação de crédito (e sua vida também).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Quem mais Quer Meus Dados?

- Não são apenas os criminosos que buscam seus dados pessoais.
- A tabela descreve outras entidades interessadas em sua identidade on-line e o motivo.

Seu provedor de serviços de Internet.	Seu ISP rastreia sua atividade on-line e, em alguns países, pode vender esses dados para os anunciantes com fins lucrativos.Em certas circunstâncias, os ISPs podem ser legalmente obrigados a compartilhar suas informações com agências ou autoridades de vigilância do governo.
Anunciantes	A publicidade direcionada faz parte da experiência na internet. Anunciantes monitoram e rastreiam suas atividades online, como hábitos de compras e preferências pessoais, e enviam anúncios direcionados para você.
Mecanismos de pesquisa e plataformas de mídia social	Essas plataformas coletam informações sobre gênero, localização geográfica, número de telefone e ideologias políticas e religiosas com base em seus históricos de pesquisa e identidade online. Essas informações são então vendidas para anunciantes visando lucro.
Sites que você visita	Os sites usam cookies para rastrear suas atividades e proporcionar uma experiência mais personalizada. Mas isso deixa um rastro de dados que está vinculado à sua identidade online e muitas vezes pode parar nas mãos de anunciantes!

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.2 Dados Corporativos

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipo dos Dados Corporativos

Dados tradicionais geralmente são gerados e mantidos por todas as organizações, grandes e pequenas.

- Ele inclui o seguinte:
  - **Dados transacionais**, como detalhes relacionados à compra e venda, atividades de produção e operações organizacionais básicas, incluindo informações usadas para tomar decisões de emprego.
  - **Propriedade intelectual**, como patentes, marcas registradas e planos de novos produtos, permite que uma empresa obtenha vantagem econômica sobre seus concorrentes. Essas informações são geralmente consideradas um segredo comercial e perdê-las pode ser desastroso para o futuro de uma empresa.
  - **Dados financeiros**, como demonstrações de renda, balanços patrimoniais e demonstrações de fluxo de caixa, fornecem insights sobre a saúde de uma empresa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Dados Organizacionais (Cont.)

A Internet das Coisas (IoT) e Big Data

- **A IoT** (Internet das Coisas) é uma grande rede de objetos físicos, como sensores, software e outros equipamentos.
- Todas essas “coisas” estão conectadas à Internet, com a capacidade de coletar e compartilhar dados.
- As opções de armazenamento de dados estão se expandindo por meio da nuvem e da virtualização.
- O surgimento da IoT levou a um crescimento exponencial dos dados, criando uma nova área de interesse em tecnologia e negócios chamada "Big Data".

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dados Organizacionais

O Cubo

Esse modelo de segurança tem três dimensões:

1. **Os princípios fundamentais para proteger sistemas de informação**



- **Confidencialidade** é um conjunto de regras que impede que informações confidenciais sejam divulgadas a pessoas, recursos e processos não autorizados. Os métodos para garantir a confidencialidade incluem **criptografia de dados**, **comprovação de identidade** e **autenticação de dois fatores**.

- **A integridade** garante que as informações ou processos do sistema sejam protegidos contra modificações intencionais ou acidentais. Uma maneira de garantir isso é usar uma **função de hash** ou **checksum**.

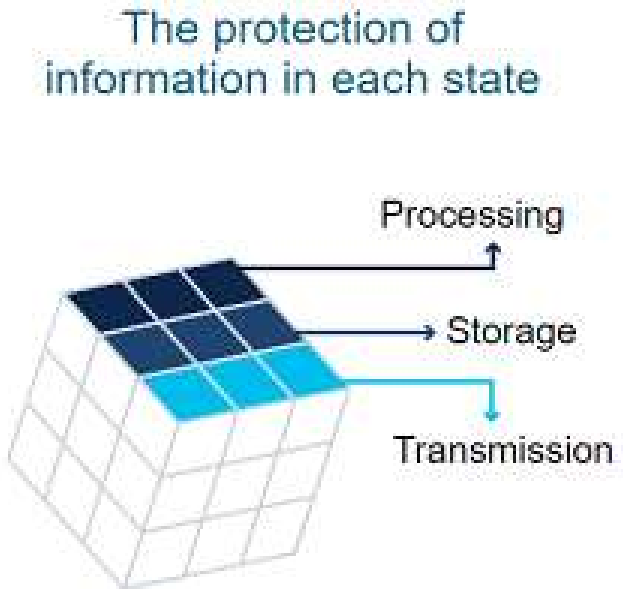
- Disponibilidade significa que os usuários autorizados podem acessar sistemas e dados quando e onde necessário, e aqueles que não atendem às condições estabelecidas, não podem. Isso pode ser alcançado por manutenção de equipamentos, realizando reparos de hardware, **mantendo os sistemas operacionais** e **software atualizadose criando de backups**.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Cubo (cont.)

2. **A proteção das informações em cada um de seus possíveis estados.**

   - **O processamento** refere-se aos dados que estão sendo usados para executar uma operação, como atualizar um registro de banco de dados (dados em processo).
   - **Armazenamento** refere-se a dados armazenados na memória ou em um dispositivo de armazenamento permanente, como um disco rígido, unidade de estado sólido ou pen drive (dados em repouso).
   - **Transmissão** refere-se a dados que viajam entre sistemas de informação (dados em trânsito).



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dados Organizacionais

O Cubo (cont.)

3. **As medidas de segurança usadas para proteger dados**

- **Conscientização, treinamento e educação** são as medidas implementadas por uma organização para garantir que os usuários estejam cientes das potenciais ameaças à segurança e das ações que podem tomar para proteger os sistemas de informação.

- **Tecnologia** refere-se às soluções baseadas em software e hardware projetadas para proteger sistemas de informação, como firewalls, que monitoram continuamente sua rede em busca de possíveis incidentes maliciosos.

- **Políticas e procedimentos** referem-se aos controles administrativos que fornecem uma base para como uma organização implementa a segurança da informação, como planos de resposta a incidentes e diretrizes de melhores práticas.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dados Organizacionais

Isso é Real?

- O phishing é muito comum e geralmente funciona.
- Por exemplo, em agosto de 2020, a marca de jogos de elite Razer sofreu uma violação de dados que expôs as informações pessoais de aproximadamente 100.000 clientes.
- Um consultor de segurança descobriu que um cluster de nuvem (um grupo de servidores vinculados fornecendo armazenamento de dados, bancos de dados, redes e software através da Internet) foi configurado incorretamente e expôs um segmento da infraestrutura da Razer à Internet pública, resultando em um vazamento de dados.
- Levou mais de três semanas para a Razer garantir que a instância na nuvem não estivesse acessível ao público, durante as quais cibercriminosos tiveram acesso a informações de clientes que poderiam ter sido usadas em ataques de engenharia social e fraudes.
- Portanto, as organizações precisam adotar uma abordagem proativa para a segurança na nuvem, garantindo que dados sensíveis estejam protegidos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Violacões de Segurança de Dados

- As violações de segurança de dados estão se tornando cada vez mais comuns, e as implicações são severas.
- A IoT está conectando cada vez mais dispositivos, criando mais oportunidades para os criminosos digitais atacarem.
- Duas violações de segurança de dados conhecidas incluem:

  - **O botnet Persirai**
    - Em 2017, um botnet da Internet das Coisas (IoT), Persirai, teve como alvo mais de 1.000 modelos diferentes de câmeras IP, acessando portas abertas para injetar um comando que obrigou as câmeras a se conectarem a um site que instalou malware nelas.
    - Depois que o malware foi baixado e executado, ele se excluiu e, portanto, foi capaz de ser executado na memória para evitar a detecção.
    - Mais de 122.000 dessas câmeras de vários fabricantes foram sequestradas e usadas para realizar ataques DDoS, sem o conhecimento de seus proprietários.
    - Um ataque de DDoS ocorre quando vários dispositivos infectados por malware inundam os recursos de um sistema visado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Violações de Segurança de Dados (cont.)

- **Equifax Inc.**
  - Em setembro de 2017, a Equifax, uma agência de relatórios de crédito ao consumidor nos EUA, anunciou publicamente um evento de violação de dados: os atacantes conseguiram explorar uma vulnerabilidade em seu software de aplicação web para obter acesso aos dados pessoais sensíveis de milhões de clientes.
  - Em resposta a essa violação, a Equifax criou um site dedicado que permitiu que seus clientes determinassem se suas informações estavam comprometidas.
  - O uso de um novo nome de domínio, em vez de usar um subdomínio equifax.com, permitiu que os criminosos criassem sites não autorizados com nomes semelhantes.
  - Esses sites foram usados para enganar os clientes e fornecer informações pessoais.
  - Os invasores podem usar essas informações para assumir a identidade de um cliente.
  - Nesses casos, seria muito difícil para o cliente provar o contrário, já que o hacker também está ciente de suas informações pessoais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dados Organizacionais

Consequências de uma Violação de Segurança

Esses exemplos mostram que as possíveis consequências de uma violação de segurança podem ser

Danos à reputação	Uma violação de segurança pode ter um impacto negativo a longo prazo na reputação de uma empresa que levou anos para ser construída. Os clientes, especialmente aqueles que foram afetados negativamente pela violação, precisarão ser notificados e poderão buscar uma compensação e / ou recorrer a um concorrente confiável e seguro. Os funcionários também podem optar por sair devido a um escândalo. Dependendo da gravidade de uma violação, pode levar muito tempo para reparar a reputação de uma empresa.
Vandalismo	Um hacker ou um grupo de hackers pode vandalizar o site de uma empresa publicando informações falsas. Eles podem até fazer algumas edições menores no número de telefone ou no endereço da empresa, o que pode ser mais difícil de detectar. Em ambos os casos, o vandalismo on-line pode retratar o não profissionalismo e ter um impacto negativo na reputação e na credibilidade da sua organização.
Roubo	Uma violação de dados geralmente envolve um incidente em que dados pessoais confidenciais foram roubados. Os criminosos digitais podem tornar essas informações públicas ou explorá-las para roubar dinheiro e/ou identidade de um indivíduo.
Perda de receita	O impacto financeiro de uma violação de segurança pode ser devastador. Por exemplo, os hackers podem derrubar o site de uma empresa, impedindo-o de fazer negócios online. A perda de todas essas informações pode impedir a expansão e o crescimento da empresa. Pode exigir mais investimento na infraestrutura de segurança de uma empresa. E não vamos esquecer que as empresas podem enfrentar grandes multas ou penalidades se não protegerem os dados online.
Propriedade intelectual prejudicada	Uma violação de segurança também pode ter um impacto devastador na competitividade de uma empresa, principalmente se os hackers conseguirem obter documentos confidenciais, segredos comerciais e propriedade intelectual.

1.3 O Que Foi Levado?

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Que Foi Roubado?

Cenário 1

- Hoje, as violações de segurança são muito comuns, com os invasores constantemente encontrando maneiras novas e inovadoras de se infiltrar nas empresas em busca de informações valiosas.
- Considere os seguintes dois cenários fictícios.

Cenário 1:

- De acordo com nossas fontes, uma conhecida cadeia de hotéis que opera em todo o mundo relatou uma violação de dados enorme, com as informações pessoais de mais de três milhões de hóspedes expostas a hackers.
- O hotel descobriu que os hackers obtiveram acesso ao banco de dados de clientes usando os detalhes de login de um de seus funcionários.
- Neste momento, o hotel não acredita que os hackers puderam acessar senhas de contas ou informações financeiras.
- Hóspedes recentes são incentivados a verificar o portal web da cadeia de hotéis para ver se eles foram afetados por essa violação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Que Foi Roubado?

Cenário 2

Cenário 2:

- A equipe da @Apollo está preocupada. As plataformas de eLearning estão se tornando os principais alvos dos invasores, à medida que mais e mais empresas migram para a aprendizagem digital.
- Uma plataforma de treinamento on-line popular admitiu ter deixado os dados pessoais de milhões de seus alunos (muitos deles menores) expostos em um banco de dados em nuvem publicamente acessível.
- Os hackers conseguiram acessar diretamente os nomes completos dos alunos, endereços de e-mail, números de telefone e detalhes de matrícula na escola pela Internet!
- Embora não esteja claro o que os hackers fizeram com essas informações adquiridas, é seguro dizer que eles têm tudo o que precisam para realizar ataques generalizados de phishing ou malware.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Que Foi Roubado?

Pontos Principais

- Uma violação de segurança é um incidente que resulta em acesso não autorizado a dados, aplicações, serviços ou dispositivos, expondo informações privadas que os invasores podem usar para ganho financeiro ou outras vantagens.
- Mas há muitas maneiras de proteger você e sua empresa.
- É importante estar ciente das ameaças digitais comuns e permanecer vigilante para que você não se torne a próxima vítima.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.4 Invasores Cibernéticos

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Invasores

- Os invasores cibernéticos variam de amadores a organizados e farão de tudo para colocar as mãos em informações pessoais.
- Eles são frequentemente classificados como invasores white hat, gray hat ou black hat.

Hackers amadores

- O termo 'script kiddies' surgiu na década de 90 e refere-se a hackers amadores ou inexperientes que usam ferramentas existentes ou instruções encontradas na Internet para lançar ataques.
- Alguns script kiddies são apenas curiosos, outros estão tentando demonstrar suas habilidades e causar danos.
- Embora esses invasores possam usar ferramentas básicas, os ataques ainda podem ter consequências devastadoras.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Atacantes (Cont.)

Hackers

- Esse grupo de atacantes invade sistemas de computadores ou redes para obter acesso.
- Dependendo da intenção da invasão, elas podem ser classificadas da seguinte forma:
  - **Atacantes white hat** invadem redes ou sistemas de computadores para identificar quaisquer vulnerabilidades, de modo que a segurança de um sistema ou rede possa ser aprimorada. Essas invasões são realizadas com permissão prévia e quaisquer resultados são relatados ao proprietário.
  - **Atacantes gray hat** podem procurar vulnerabilidades em um sistema, mas só relatarão suas descobertas aos proprietários do sistema se isso estiver alinhado com sua agenda. Alguns hackers gray hat publicam os fatos sobre a vulnerabilidade na Internet para que outros invasores possam explorá-la.
  - **Invasores black hat** tiram vantagem de qualquer vulnerabilidade para obter ganhos pessoais, financeiros ou políticos ilegais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Atacantes (Cont.)

Hackers organizados

- Esses criminosos incluem organizações de hacktivistas, criminosos virtuais, terroristas e os hackers patrocinados pelo Estado.
- Os criminosos são altamente sofisticados e organizados e ainda podem fornecer o crime digital como um serviço a outros criminosos.
- Os hacktivistas fazem declarações políticas para sensibilizar para questões que são importantes para eles.
- Os invasores patrocinados pelo estado reúnem informações ou cometem sabotagem em nome de seu governo.
- Eles geralmente são altamente treinados e bem financiados, e seus ataques são focados em objetivos específicos que são benéficos para seu governo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças Internas e Externas

- Os ataques cibernéticos podem se originar dentro e fora da empresa.

- **Interno**
  - Funcionários, contratados ou parceiros confiáveis podem, acidental ou intencionalmente:
    - manipular dados confidenciais de forma incorreta
    - facilitar ataques externos conectando mídia USB infectada ao sistema de computador da organização
    - introduzir malware na rede da organização ao clicar em e-mails ou sites maliciosos
    - ameaçar as operações de servidores internos ou dispositivos de infraestrutura de rede

- **Externo**
  - Os amadores ou invasores qualificados fora da empresa podem:
    - explorar vulnerabilidades na rede
    - obter acesso não autorizado a dispositivos de computação
    - usar a engenharia social para obter acesso não autorizado a dados organizacionais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.5 Guerra Cibernética

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Guerra Cibernética

Sinal dos Tempos (Stuxnet)

- Um exemplo de ataque patrocinado pelo estado envolveu o malware Stuxnet, que foi projetado não apenas para invadir computadores de destino , mas também para causar danos físicos a equipamentos controlados por computadores!

- Assista a um vídeo curto sobre o caso do Stuxnet e descubra o impacto que esse malware teve na planta de enriquecimento nuclear do Irã.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Propósito da Guerra Cibernética

- A principal razão para recorrer à ciberguerra é obter vantagem sobre adversários, sejam eles nações ou concorrentes.
- A guerra cibernética é usada das seguintes maneiras:

- **Para coletar informações comprometidas e/ou segredos de defesa**

  - Uma nação ou organização internacional pode se envolver em uma guerra cibernética para roubar segredos de defesa e obter informações sobre tecnologias que ajudarão a reduzir as lacunas em suas indústrias e capacidades militares.

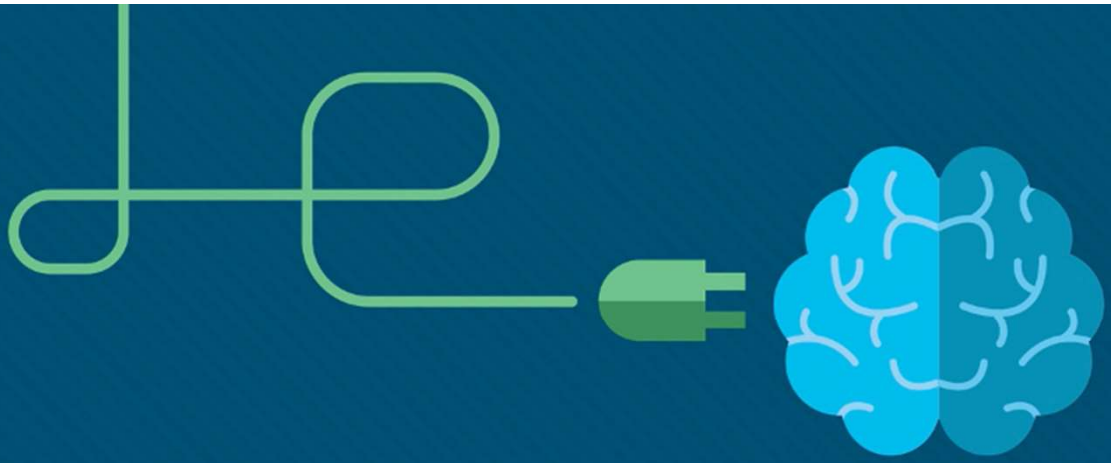
  - Além disso, dados sensíveis comprometidos podem dar aos atacantes uma alavanca para chantagear pessoal dentro de um governo estrangeiro.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Propósito da Guerra Cibernética (Cont.)

- **Para impactar a infraestrutura de outra nação**
  - Além da espionagem industrial e militar, uma nação pode invadir continuamente a infraestrutura de outra nação para causar disrupção e caos.
  - Por exemplo, um ataque pode interromper a rede de energia de uma grande cidade.
  - Considere as consequências se isso acontecesse; as estradas estariam congestionadas, a troca de bens e serviços seria interrompida, os pacientes não conseguiriam receber o cuidado necessário em caso de emergência, o acesso à internet seria interrompido.
  - Ao desligar uma rede elétrica, um ataque digital pode ter um grande impacto no dia a dia dos cidadãos comuns.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 2: Ataques, Conceitos e Técnicas



Introdução à Cibersegurança

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Objetivos do Módulo

Título do Módulo: Ataques, Conceitos e Técnicas

Objetivo do Módulo: Explicar as ameaças, ataques e vulnerabilidades cibernéticas mais comuns.

Título do Tópico	Objetivo do Tópico
Analisando um ataque cibernético	Identificar os diferentes tipos de malware e seus sintomas.
Métodos de infiltração	Descrever os diferentes métodos de infiltração.
Exploits e vulnerabilidade de segurança	Explicar como encontrar as vulnerabilidades de segurança.
O cenário da Segurança Cibernética	Explicar como categorizar as vulnerabilidades de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
36

2.1 Análise de um Ataque Cibernético

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Malware

- Os criminosos digitais usam muitos tipos diferentes de software mal-intencionado, ou malware, para realizar suas atividades. O uso de malware refere-se a qualquer código que possa roubar dados, burlar controles de acesso ou causar danos ou comprometer um sistema. Conhecer os diferentes tipos e como eles se espalham é fundamental para contê-los e removê-los.

Spyware:

- O spyware monitora sua atividade online e pode registrar cada tecla que você pressiona no teclado e capturar quase todos os seus dados, incluindo informações pessoais confidenciais, como dados bancários online. O objetivo dele é rastrear e espionar você. O spyware faz isso modificando as configurações de segurança dos dispositivos.

- Muitas vezes, o spyware se junta ao software legítimo ou a cavalos de Troia.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
38

Tipos de Malware (continuação)

Adware:

- Freqüentemente o adware é instalado junto com algumas versões de software e seu objetivo é entregar anúncios automaticamente a um usuário, geralmente em um navegador da web. Você sabe quando vê! É difícil ignorar quando você enfrenta anúncios pop-up constantes na tela.
- É comum o adware vir com spyware.

Backdoor:

- Este malware obtém acesso não autorizado, ignorando os procedimentos normais de autenticação, para acessar um sistema. Como resultado, os hackers podem acessar recursos de dentro de um aplicativo e emitir comandos remotos de sistema.
- Um backdoor funciona em segundo plano e é difícil de detectar.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 39

Tipos de Malware (continuação)

Ransomware:

- O projeto desse malware é manter como refém um sistema de computador ou os dados que ele contém até que seja feito um pagamento. O ransomware geralmente criptografa as informações para que você não possa acessá-las.
- Algumas versões de ransomware podem tirar proveito de vulnerabilidades específicas do sistema para bloqueá-lo. O ransomware é frequentemente disseminado por e-mails de phishing que o incentivam a baixar um anexo mal-intencionado ou uma vulnerabilidade de software.

Scareware:

- Este tipo de malware usa táticas de “sustos” para induzi-lo a realizar uma ação específica. O scareware consiste principalmente em janelas do tipo sistema operacional que avisam que seu sistema está em risco e precisa executar um programa específico para retornar à operação normal.
- Se você concordar em executar o programa específico, seu sistema será infectado por malware.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
40

Tipos de Malware (continuação)

Rootkit:

- O objetivo desse malware é modificar o sistema operacional para criar um backdoor, que os invasores podem usar para acessar seu computador remotamente. A maioria dos rootkits usa vulnerabilidades de software para acessar recursos que não deveriam estar acessíveis (escalonamento de privilégios) e modificar arquivos do sistema.
- Os Rootkits também podem modificar as ferramentas forenses e de monitoramento do sistema, tornando-os muito difíceis de detectar. Se um rootkit infectar um computador, formate o computador e reinstale qualquer software necessário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 41

Tipos de Malware (continuação)

Vírus:

- Um vírus é um programa de computador que, quando executado, se replica e se anexa a outros arquivos executáveis, como um documento, inserindo seu código. A maioria dos vírus exige a interação do usuário final para iniciar a ativação e pode agir em uma data ou hora específica.
- Os vírus, como aqueles que exibem uma imagem engraçada, podem ser relativamente inofensivos. Ou podem ser destrutivos, como os que modificam ou excluem dados.
- Os vírus também podem ser programados para se modificar e evitar a detecção. Unidades USB, discos ópticos, compartilhamentos de rede ou e-mail espalham a maioria dos vírus.

Cavalo de Tróia

- Esse malware realiza operações mal-intencionadas mascarando sua verdadeira intenção. Parece legítimo, mas é muito perigoso. Os cavalos de Troia exploram os privilégios do usuário, e é comum encontrá-los em arquivos de imagem, arquivos de áudio ou jogos.
- Ao contrário dos vírus, os cavalos de Troia não se replicam automaticamente, mas agem como iscas para que o software malicioso passe despercebido pelos usuários desavisados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
42

Tipos de Malware (continuação)

Worms:

- Esse tipo de malware se replica para se espalhar de um computador para outro. Ao contrário de um vírus, que requer um programa hospedeiro, os worms podem ser executados sozinhos. Além da infecção inicial do host, eles não exigem a participação do usuário e podem se espalhar rapidamente pela rede.
- Os worms compartilham padrões semelhantes: eles exploram vulnerabilidades do sistema, têm uma maneira de se propagar e todos contêm código malicioso (carga útil) para causar danos a sistemas ou redes de computadores.
- Os worms são responsáveis por alguns dos ataques mais devastadores na Internet. Em 2001, o worm Code Red infectou mais de 300.000 servidores em apenas 19 horas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
43

Sintomas de Malware

Independentemente do tipo de malware que infecta um sistema, você pode observar alguns sintomas comuns. Isso inclui:

- um aumento no uso da unidade de processamento central (CPU), o que torna o dispositivo mais lento
- seu computador congelando ou travando frequentemente
- uma diminuição na velocidade de navegação na web
- problemas inexplicáveis com suas conexões de rede
- arquivos modificados ou excluídos
- a presença de arquivos, programas ou ícones desconhecidos na área de trabalho
- processos desconhecidos em execução
- programas desligando ou se reconfigurando
- envio e-mails sem o seu conhecimento ou consentimento.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 44

2.2 Métodos de Infiltração

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 45

Métodos de Infiltração

Engenharia Social

- A engenharia social está manipulando as pessoas para que realizem ações ou divulguem informações confidenciais. Os engenheiros sociais frequentemente contam com a disposição das pessoas em serem prestativas, mas também exploram suas fraquezas.
- Por exemplo, um invasor poderá ligar para um funcionário autorizado com um problema urgente que exija acesso imediato à rede e apelará à vaidade ou ganância do funcionário ou invocará autoridade usando técnicas de menção de nomes para obter esse acesso.

Pretexting

- É quando um invasor liga para um indivíduo e mente para obter acesso a dados confidenciais.
- Por exemplo, fingir que precisa dos dados pessoais ou financeiros de uma pessoa para confirmar a sua identidade.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
46

Métodos de Infiltração

Engenharia Social (Cont.)

- **Tailgating (seguir de perto)**
  - Isso ocorre quando um invasor segue rapidamente uma pessoa autorizada até um local físico seguro.

- **Algo por algo (Quid pro quo)**
  - É quando um invasor solicita informações pessoais de alguém em troca de algo, como um presente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 47

Métodos de Infiltração

Negação de Serviço (DoS)

Os ataques de negação de serviço (DoS) são um tipo de ataque de rede que é relativamente simples de ser realizado, mesmo por um atacante sem habilidades avançadas. Um ataque DoS resulta em alguma interrupção do serviço de rede para usuários, dispositivos ou aplicativos.

Quantidade Esmagadora de Tráfego

- Isso ocorre quando uma rede, host ou aplicativo envia uma enorme quantidade de dados a uma taxa que não consegue suportar. Isso causa uma transmissão ou resposta lenta ou faz com que o dispositivo ou serviço trave.

Pacotes formatados maliciosamente

- Um pacote é uma coleta de dados que flui entre uma fonte e um computador receptor ou aplicativo através de uma rede, como a Internet. Ao enviar um pacote formatado maliciosamente, o destinatário não consegue lidar com ele.
- Por exemplo, suponha que um invasor encaminhe pacotes contendo erros ou pacotes formatados incorretamente que um aplicativo não consegue identificar. Nesse caso, isso fará com que o dispositivo receptor funcione muito lentamente ou trave.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de Infiltração

DoS Distribuída

Um ataque de Negação de Serviço Distribuído (DDoS) é semelhante a um ataque de Negação de Serviço (DoS), mas tem origem em múltiplas fontes coordenadas. Por exemplo:

- Um invasor constrói uma rede (botnet) de hosts infectados chamados zumbis, controlados por sistemas manipuladores.
- Os computadores zumbis examinam e infectam constantemente mais hosts, criando mais zumbis.
- Quando está pronto, o hacker instrui os sistemas controlador para fazer com que o botnet de zumbis execute um ataque de negação de serviço distribuído (DDoS).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
49

Métodos de Infiltração

Botnet

- Um computador bot normalmente é infectado ao visitar um site inseguro ou abrir um anexo de e-mail ou arquivo de mídia infectado. Uma botnet é um grupo de bots conectados pela Internet que um indivíduo ou grupo mal-intencionado pode controlar. Pode ter dezenas de milhares ou mesmo centenas de milhares de bots que, normalmente, são controlados por um servidor de comando e controle.

- A ativação desses bots distribui malware, lança ataques DDoS, distribui e-mails de spam ou executa ataques de força bruta de senha. Os cibercriminosos freqüentemente alugam botnets para terceiros para fins nefastos.

- Muitas organizações, como a Cisco, direcionam as atividades de rede através de filtros de tráfego de botnets para identificar possíveis localizações de botnets.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 50

Métodos de Infiltração

Botnet (cont.)

1. Os bots infectados tentam se comunicar com um host de comando e controle na Internet.

2. O filtro de botnet do Cisco Firewall é um recurso que detecta o tráfego proveniente de dispositivos infectados com o código mal-intencionado do botnet.

3. O serviço Cisco Security Intelligence Operations (SIO) na nuvem envia os filtros atualizados para o firewall, que corresponde ao tráfego de novos botnets conhecidos.

4. Os alertas vão para a equipe de segurança interna da Cisco para notificá-los sobre os dispositivos infectados que geram tráfego malicioso, para que possam prevenir, mitigar e remediar.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
51

Métodos de Infiltração

Ataques On-Path

- Os invasores no caminho interceptam ou modificam as comunicações entre dois dispositivos, como um navegador da Web e um servidor da Web, para coletar informações ou se passar por um dos dispositivos.

- Esse tipo de ataque se refere a um ataque do tipo "man-in-the-middle" ou "man-in-the-mobile".

Man-in-the-middle

- Um ataque de MitM acontece quando um criminoso digital assume o controle de um dispositivo sem o conhecimento do usuário. Com esse nível de acesso, um invasor pode interceptar e capturar informações do usuário antes de enviá-las ao destino pretendido. O uso desses tipos de ataques geralmente rouba informações financeiras.
- Existem muitos tipos de malware que possuem recursos de ataque de MitM.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
52

Ataques On-Path (Cont.)

Man-in-the-Mobile

- Uma variação do man-in-middle, MitMo é um tipo de ataque usado para assumir o controle do dispositivo móvel de um usuário. Quando infectado, as instruções do dispositivo móvel exfiltram informações sensíveis do usuário e as enviam para os atacantes. O ZeuS é um exemplo de pacote de malware com recursos MitMo. Ele permite que os invasores capturem mensagens SMS de verificação em duas etapas enviadas aos usuários silenciosamente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
53

Métodos de Infiltração

Envenenamento de SEO

- Você provavelmente já ouviu falar de otimização de mecanismos de pesquisa ou SEO, que consiste em melhorar o site de uma organização para obter maior visibilidade nos resultados de pesquisas.
- Mecanismos de pesquisa como o Google funcionam apresentando uma lista de páginas da web aos usuários com base em suas consultas de pesquisa. Essas páginas da web são classificadas de acordo com a relevância de seu conteúdo.
- Embora muitas empresas legítimas se especializem na otimização de sites para melhor posicioná-los, os invasores aproveitam termos de pesquisa populares e usam SEO para empurrar sites maliciosos para uma posição mais elevada nos resultados de pesquisa. Esta técnica é chamada de SEO poisoning.
- O objetivo mais comum do SEO poisoning é aumentar o tráfego para sites maliciosos que podem hospedar malware ou tentar engenharia social.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
54

Métodos de Infiltração

Ataques de Senha

Inserir um nome de usuário e senha é uma das formas mais populares de autenticação em um site. Portanto, descobrir a senha é uma maneira fácil para os criminosos digitais obterem acesso às informações mais importantes.

Pulverização de senha:

- Esta técnica tenta obter acesso a um sistema 'dispersando' algumas senhas comumente usadas em muitas contas. Por exemplo, um criminoso digital usa 'Password123' com muitos nomes de usuário antes de tentar novamente com uma segunda senha comumente usada, como 'qwerty'.
- Essa técnica permite que o perpetrador permaneça sem ser detectado e evite bloqueios frequentes de contas.

Ataques de dicionário:

- Um hacker tenta sistematicamente cada palavra de um dicionário ou de uma lista de palavras comumente usadas como senha para invadir uma conta protegida por senha.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques a Senhas (Continuação)

Ataques de força bruta

- A maneira mais simples e comumente usada de obter acesso a um site protegido por senha, os ataques de força bruta fazem com que um invasor use todas as combinações possíveis de letras, números e símbolos no espaço da senha até acertar.

Ataques Rainbow

- As senhas em um sistema de computador não são armazenadas como texto simples, mas como valores hash (valores numéricos que identificam os dados de maneira exclusiva). Uma tabela de Rainbow funciona como um extenso dicionário de hashes e senhas pré-computadas.
- Ao contrário de um ataque de força bruta que precisa calcular cada hash, um ataque do arco-íris compara o hash de uma senha com os armazenados na tabela do arco-íris. Quando um invasor encontra uma correspondência, ele identifica a senha usada para criar o hash.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
56

Métodos de Infiltração

Ataques a Senhas (Continuação)

Interceptação de tráfego

- Ao interceptar comunicações, outros humanos e máquinas podem ler facilmente texto simples ou senhas não criptografadas.
- Se você armazenar uma senha em texto claro e legível, qualquer pessoa que tenha acesso à sua conta ou dispositivo, autorizado ou não autorizado, poderá lê-la.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 57

Métodos de Infiltração

Ameaças Persistentes Avançadas

- Os invasores também conseguem infiltração por meio de ameaças persistentes avançadas (APTs) — uma operação multifásica, de longo prazo, furtiva e avançada contra um alvo específico. Por essas razões, um invasor individual muitas vezes não possui o conjunto de habilidades, recursos ou persistência para executar APTs.

- Devido à complexidade e ao nível de habilidade necessários para realizar tal ataque, uma APT é geralmente bem financiada e tem como alvo organizações ou nações por razões comerciais ou políticas.

- Seu objetivo principal é implantar malware personalizado em um ou mais sistemas do alvo e permanecer lá sem ser detectado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
58

2.3 Exploits e Vulnerabilidade de Segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
59

Exploits e Vulnerabilidade de Segurança

Vulnerabilidades de Hardware/fusão e Espectro

As vulnerabilidades de hardware são geralmente o resultado de falhas de design de hardware.

- Por exemplo, o tipo de memória chamada RAM consiste em muitos capacitores (um componente que pode acumular carga elétrica) instalados muito próximos uns dos outros.
- Porém, devido à sua proximidade, alterações aplicadas a um desses capacitores podem influenciar os capacitores vizinhos.
- Essa falha de design cria uma exploração chamada Rowhammer. Ao acessar repetidamente (hammering - martelar) uma linha de memória, o exploit Rowhammer desencadeia interferências elétricas que, eventualmente, corrompem os dados armazenados na RAM.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 60

Vulnerabilidades de Hardware Meltdown e Spectre (continuação)

Meltdown e Spectre

- Os pesquisadores de segurança do Google descobriram o Meltdown e o Spectre, duas vulnerabilidades de hardware que afetam quase todas as unidades centrais de processamento (CPUs) lançadas desde 1995 em desktops, laptops, servidores, smartphones, dispositivos inteligentes e serviços em nuvem.

- Os invasores que exploram essas vulnerabilidades podem ler toda a memória de um determinado sistema (Meltdown) e dados manipulados por outros aplicativos (Spectre). As explorações das vulnerabilidades Meltdown e Spectre referem-se a ataques de canal lateral (a implementação de um sistema de computador obtém informações). Essas vulnerabilidades podem comprometer grandes quantidades de dados na memória devido ao grande número de vezes que os ataques são executados em um sistema, com mínima possibilidade de falhas ou outros erros.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
61

Exploits e Vulnerabilidade de Segurança

Vulnerabilidades de Software

- Erros no sistema operacional ou no código do aplicativo geralmente introduzem **vulnerabilidades de software**.
- A vulnerabilidade SYNful Knock permitiu que os invasores ganhassem o controle de roteadores de nível empresarial, como os roteadores Cisco ISR antigos, dos quais poderiam monitorar toda a comunicação de rede e infectar outros dispositivos de rede.
- Quando uma versão alterada do IOS é instalada nos roteadores, essa vulnerabilidade é introduzida no sistema. Para evitar isso, sempre verifique a integridade da imagem do IOS baixada e limite o acesso físico do equipamento somente ao pessoal autorizado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Categorizando Vulnerabilidades de Software

A maioria das vulnerabilidades de segurança de software se enquadra em várias categorias principais.

Buffer Overflow:

- Os buffers são áreas de memórias alocadas a um aplicativo. Ao gravar dados além dos limites de um buffer, ocorre uma vulnerabilidade. Ao alterar os dados além dos limites de um buffer, o aplicativo pode acessar a memória alocada para outros processos. Isso pode levar à queda do sistema, comprometimento de dados ou fornecer o escalonamento de privilégios.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
63

Categorizando Vulnerabilidades de Software (Cont.)

Entrada não validada

- Programas frequentemente necessitam de entrada, mas esses dados recebidos podem conter conteúdo malicioso que, inadvertidamente, faz o programa se comportar de maneira inesperada ou prejudicial.
- Por exemplo, considere um programa que recebe uma imagem para processamento. Um usuário mal-intencionado pode criar um arquivo de imagem com dimensões de imagem inválidas. As dimensões criadas de forma mal-intencionada podem forçar o programa a alocar buffers de tamanhos incorretos e inesperados.

Condições de corrida:

- Esta vulnerabilidade descreve uma situação em que a saída de um evento depende de saídas ordenadas ou cronometradas. Uma condição de corrida tornou-se uma fonte de exposição quando os eventos ordenados ou cronometrados exigidos não ocorreram na ordem correta ou no momento adequado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
64

Categorizando Vulnerabilidades de Software (Cont.)

Fraquezas nas práticas de segurança:

- Autenticação, autorização e criptografia protegem sistemas e dados confidenciais. Os desenvolvedores devem usar técnicas e bibliotecas de segurança que já foram criadas, testadas e verificadas e não devem tentar criar seus algoritmos de segurança. É provável que elas introduzam novas vulnerabilidades.

Problemas de controle de acesso:

- O controle de acesso é o processo de controlar quem faz o quê e abrange desde o gerenciamento do acesso físico ao equipamento até ditar quem tem acesso a um recurso, como um arquivo, e o que pode ser feito com ele, como ler ou alterar o arquivo. O uso indevido de controles de acesso cria muitas vulnerabilidades de segurança.
- Quase todos os controles de acesso e as práticas de segurança poderão ser superados se o invasor tiver acesso físico ao equipamento de destino. Por exemplo, não importa as configurações de permissão em um arquivo, um hacker pode ignorar o sistema operacional e ler os dados diretamente do disco.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 65

Exploits e Vulnerabilidade de Segurança

Atualizações de Software

- O objetivo das atualizações de software é manter-se atualizado e evitar a exploração de vulnerabilidades. Microsoft, Apple e outros produtores de sistemas operacionais lançam patches e atualizações diariamente. As empresas ou organizações, responsáveis por eles, atualizam aplicativos, como navegadores da web, aplicativos móveis e servidores web.

- Embora as organizações se esforcem muito para encontrar e corrigir vulnerabilidades de software, elas descobrem novas vulnerabilidades regularmente. Por isso, algumas organizações utilizam pesquisadores de segurança terceirizados especializados em encontrar vulnerabilidades em software, ou investem em suas próprias equipes de teste de penetração dedicadas a buscar, identificar e corrigir vulnerabilidades de software antes que possam ser exploradas.

- O Projeto Zero do Google é um excelente exemplo dessa prática. Depois de descobrir diversas vulnerabilidades em diversos softwares usados pelos usuários finais, o Google formou uma equipe permanente dedicada a encontrar vulnerabilidades de software. Você pode descobrir mais sobre a pesquisa de segurança do Google aqui.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
66

2.4 O Cenário de Segurança Cibernética

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
67

Criptomoeda

- Criptomoeda é dinheiro digital usado para comprar bens e serviços, usando fortes técnicas de criptografia para proteger transações online. Bancos, governos e até empresas como a Microsoft e a AT&T estão muito conscientes da sua importância e estão aderindo ao movimento das criptomoedas!

- Os proprietários de moedas criptografadas guardam seu dinheiro em “carteiras” virtuais e criptografadas. Quando ocorre uma transação entre os proprietários de duas carteiras digitais, os detalhes são registrados em um sistema descentralizado, um registro eletrônico ou blockchain. Isso significa que é realizado de forma anônima e é autogerenciado, sem interferência de terceiros, como bancos centrais ou entidades governamentais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
68

Criptomoeda (cont.)

- Computadores especiais coletam dados sobre as últimas transações de criptomoedas a cada dez minutos, transformando-os em desafios matemáticos para manter a confidencialidade.
- A verificação destas transações passa por um processo técnico e altamente complexo conhecido como “mineração”. Esta etapa normalmente envolve um exército de “mineradores” trabalhando em PCs de última geração para resolver desafios matemáticos e autenticar transações.
- Uma vez verificado, o registro é atualizado, copiado eletronicamente e disseminado globalmente para qualquer pessoa dentro da rede blockchain, efetivamente concluindo uma transação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

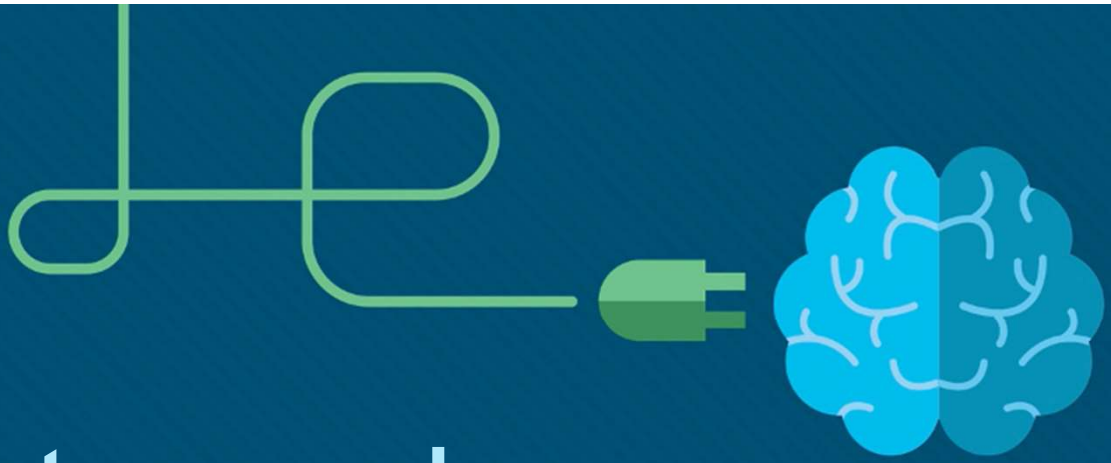
Cryptojacking

- **Cryptojacking** é uma ameaça emergente que se esconde no computador, celular, tablet, laptop ou servidor de um usuário, usando os recursos dessa máquina para “minerar” criptomoedas sem o consentimento ou conhecimento do usuário.

- Muitas vítimas de cryptojacking nem sabiam que tinham sido hackeadas até que fosse tarde demais!

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 3: Protegendo seus Dados e Privacidade



Introdução à Cibersegurança

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Objetivos do Módulo

Título do Módulo : Protegendo seus Dados e Privacidade

Objetivo do Módulo: Explique como se proteger enquanto estiver online

Título do Tópico	Objetivo do Tópico
Como proteger a rede e os dispositivos	Identificar as formas de proteger os dispositivos de informática.
Manutenção de dados	Usar redes sem fio com segurança
Quem é o dono dos seus dados?	Criar senhas fortes.
Como proteger a privacidade on-line	Implementar técnicas para manter os dados com segurança.
Descobrir seu próprio comportamento on-line arriscado	Explicar as formas de aumentar a segurança dos dados on-line.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 72

3.1 Protegendo Seus Dispositivos e sua Rede

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
73

Como Proteger a Rede e os Dispositivos

Protegendo seus Dispositivos e a Rede

- Algumas dicas importantes sobre como proteger a segurança dos dispositivos:

Ative o firewall	Você deve usar pelo menos um tipo de firewall (firewall de software ou de hardware em um roteador) para proteger seu dispositivo contra acesso não autorizado. O firewall deve estar ativado e atualizado constantemente para impedir que hackers acessem seus dados pessoais ou da empresa.
Instalar antivírus e antispyware	Software malicioso, como vírus e spyware, é projetado para obter acesso não autorizado ao seu computador e aos seus dados. Uma vez instalado, os vírus podem destruir os dados e tornar seu computador mais lento. Eles podem até assumir o controle do computador e transmitir e-mails de spam usando a conta. O spyware pode monitorar suas atividades on-line, coletar informações pessoais ou produzir anúncios pop-up indesejados no navegador da Web, enquanto você estiver on-line. Para evitar isso, você só deve baixar software de sites confiáveis. No entanto, ajudaria se você sempre usasse software antivírus para fornecer outra camada de proteção. Este software, que geralmente inclui antispyware, foi projetado para verificar a presença de vírus em seu computador e nos e-mails recebidos e excluí-los.
Gerencie seu sistema operacional e navegador	Os hackers estão sempre tentando tirar vantagem das vulnerabilidades do seu sistema operacional ou navegador da web. Portanto, para proteger o seu computador e os seus dados, você deve definir as configurações de segurança do seu computador e navegador para um nível médio ou superior. Você também deve atualizar regularmente o sistema operacional do seu computador, incluindo o navegador da web, e baixar e instalar os patches de software e atualizações de segurança mais recentes dos fornecedores.
Configurar proteção por senha	Todos os seus dispositivos de computação devem ser protegidos por senha para evitar acesso não autorizado. Qualquer informação armazenada, especialmente dados sensíveis ou confidenciais, deve ser criptografada. Você só deve armazenar as informações necessárias em seu dispositivo móvel, para o caso de ser roubado ou perdido. Lembre-se, se algum dos seus dispositivos for comprometido, os criminosos poderão acessar todos os dados através do seu provedor de serviços de armazenamento em nuvem, como iCloud ou Google Drive.

Protegendo seus Dispositivos e Rede

Segurança de Rede Sem fio em Casa

- As redes sem fio permitem que os dispositivos habilitados para Wi-Fi se conectem à rede por meio de um SSID.
- Um roteador sem fio pode ser configurado para não transmitir o SSID, mas é necessário que haja segurança adequada para uma rede sem fio.
- Os hackers estarão cientes do SSID e da senha padrão predefinidos, portanto, para evitar que invasores entrem na rede sem fio doméstica, você deve alterar esses detalhes.
- Além disso, você pode criptografar a comunicação sem fio ativando a segurança sem fio e o recurso de criptografia WPA2 em seu roteador sem fio.
- Mas esteja ciente de que, mesmo com a criptografia WPA2 habilitada, uma rede sem fio ainda pode ser vulnerável.

- **Descoberta de uma falha de segurança no protocolo WPA2 em 2017**
  - Os ataques de reinstalação de chave (KRACKs) realizados por invasores que quebram a criptografia entre um roteador sem fio e um dispositivo sem fio, dando a eles acesso aos dados de rede, podem explorar essa vulnerabilidade.
  - Essa falha afeta todas as redes Wi-Fi modernas e protegidas e, para mitigar essa situação, você deve:
  - Atualize todos os dispositivos com capacidade sem fio assim que as atualizações de segurança estiverem disponíveis
  - Use uma conexão com fio para qualquer dispositivo com uma NIC com fio
  - Use um serviço VPN confiável ao acessar uma rede sem fio.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Riscos de Wi-Fi Público

- Quando você está longe de casa, pode acessar suas informações online e navegar na Internet por meio de redes sem fio públicas ou pontos de acesso Wi-Fi.
- No entanto, existem alguns riscos envolvidos, o que significa que é melhor não aceder ou enviar informações pessoais através de redes Wi-Fi públicas.
- Ajudaria se você verificasse continuamente que seu dispositivo não está configurado com compartilhamento de arquivos e mídia e requer autenticação de usuário com criptografia.
- Você também deve usar um serviço de VPN criptografado para impedir que outras pessoas interceptem suas informações (conhecidas como "eavesdropping" ou "escutas") em uma rede pública sem fio.
- Este serviço oferece acesso seguro à Internet, criptografando a conexão entre o seu dispositivo e o servidor VPN.
- Mesmo que os hackers interceptem uma transmissão de dados em um túnel VPN criptografado, eles não conseguirão decifrá-la.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Como Proteger a Rede e os Dispositivos

Uma Senha Forte

- Aqui estão algumas dicas simples para ajudá-lo na escolha de uma senha forte.

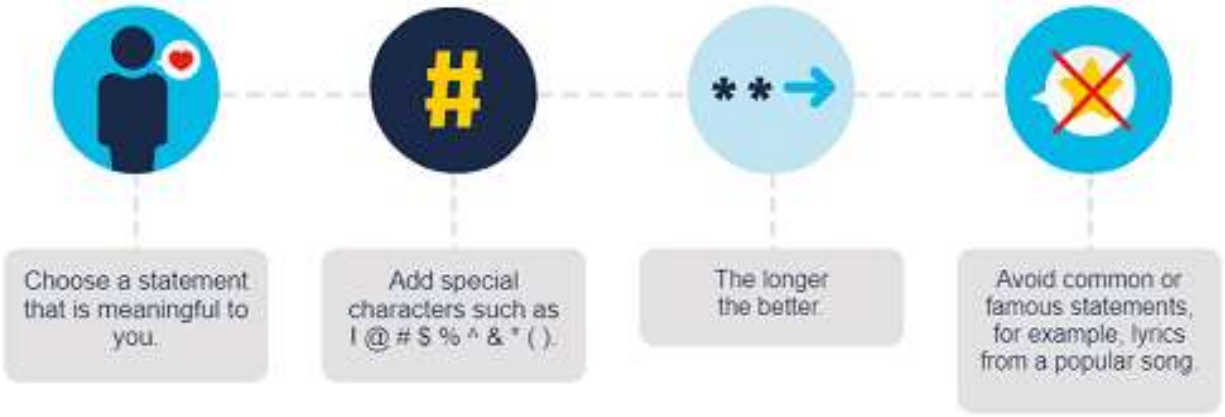


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
77

Uso de Uma Frase Secreta

- Ajudaria se você considerasse usar de frase secreta em vez de senhas para evitar acesso não autorizado aos seus dispositivos.
- Uma frase secreta geralmente tem a forma de uma frase ("Acat th@tlov3sd0gs."), tornando mais fácil para você se lembrar.
- E como é mais do que uma senha típica, é menos vulnerável a ataques de força bruta ou de dicionário.
- Aqui estão algumas dicas para criar uma boa senha.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
78

Diretrizes de Senha

- O Instituto Nacional de Padrões e Tecnologia (NIST) dos Estados Unidos publicou requisitos de senha aprimorados.
- Os padrões NIST destinam-se a aplicações governamentais, mas também podem servir como padrão para outros setores.
- Essas diretrizes visam atribuir a responsabilidade de verificação de usuário aos provedores de serviços e garantir uma experiência melhor para os usuários em geral.
- Eles afirmam:
  - As senhas devem ter no mínimo oito caracteres, mas não mais que 64 caracteres.
  - Senhas comuns e fáceis de adivinhar, como ‘senha’ ou ‘abc123’, não devem ser usadas.
  - Não devem existir regras de composição, incluindo letras maiúsculas e minúsculas e números
  - Os usuários devem poder ver a senha ao digitar para ajudar a melhorar a precisão.
  - Todos os caracteres e espaços devem ser permitidos.
  - Não deve haver dicas de senha.
  - Não deve haver período de expiração de senha.
  - Não deve haver autenticação baseada em conhecimento, como fornecer respostas a perguntas secretas ou verificar o histórico de transações.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.2 Manutenção de Dados

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 80

Manutenção de Dados

O Que é Criptografia?

- Criptografia é o processo de converter informações em um formato no qual pessoas não autorizadas não possam lê-las.
- Somente uma pessoa confiável e autorizada com uma chave ou senha secreta pode descriptografar os dados e acessá-los em sua forma original.
- Observe que a criptografia em si não impede que alguém intercepte os dados.
- Ele só pode impedir que uma pessoa não autorizada veja ou acesse o conteúdo.
- Alguns criminosos podem criptografar seus dados e torná-los inutilizáveis até que você pague um resgate.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

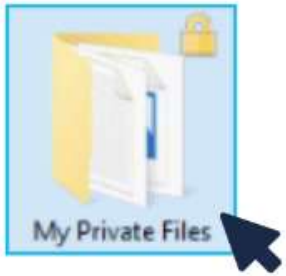
© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
81

Manutenção de Dados

Como Você Criptografa Seus Dados?

- O uso de programas de software serve para criptografar arquivos, pastas e até unidades inteiras.
- EFS é um recurso do Windows que pode criptografar dados. Ele se vincula diretamente a uma conta de usuário específica e somente o usuário que criptografa os dados pode acessá-los após a criptografia usando EFS.
- Como criptografar dados usando EFS em todas as versões do Windows:

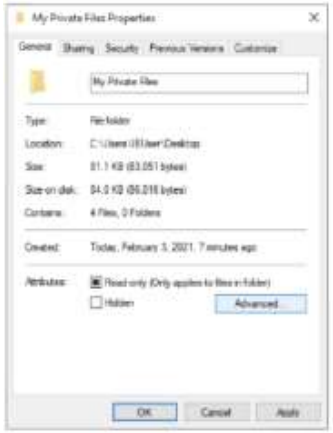
Passo 1
Selecione um ou mais arquivos ou pastas.



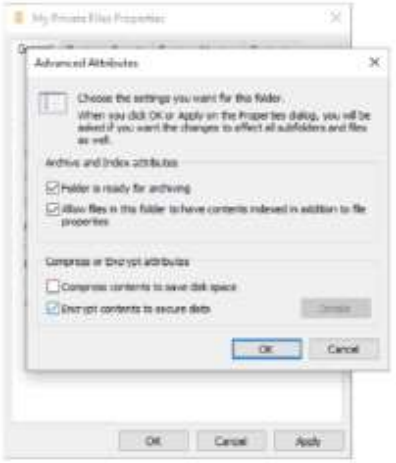
Passo 2
Clique com o botão direito nos dados selecionados e vá para '**Propriedades**'.



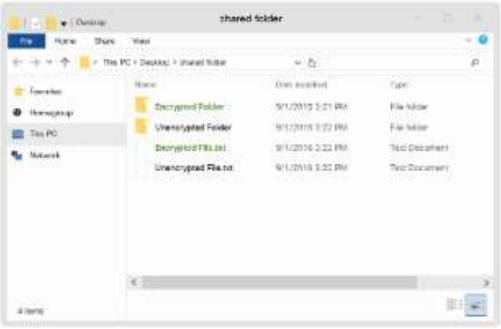
Passo 3
Encontre e clique em '**Avançado**'.



Passo 4
Marque **a caixa de seleção 'Criptografar conteúdo para proteger dados**'.



Passo 5
Arquivos e pastas criptografados com EFS são exibidos em verde.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Manutenção de Dados

Backup dos Seus Dados

- Ter um backup pode evitar a perda de dados insubstituíveis.
- Para fazer backup dos dados corretamente, você precisará de um local de armazenamento adicional e deverá copiar os dados para esse local regularmente.

Alguns destes locais de armazenamento adicionais:

Rede residencial	Armazenar seus dados localmente significa que você tem controle total sobre eles.
Local secundário	Você pode copiar todos os seus dados para um NAS, um disco rígido externo simples ou talvez até fazer backup de pastas importantes em pen drives, CDs, DVDs ou fitas. Neste cenário, você é o proprietário dos dados e é responsável pelo custo e pela manutenção do equipamento do dispositivo de armazenamento.
A nuvem	Você poderia assinar um serviço de armazenamento em nuvem, como AWS. O custo deste serviço dependerá do espaço de armazenamento necessário, portanto, talvez seja necessário ser mais seletivo quanto aos dados dos quais você faz backup. Você terá acesso aos seus dados de backup contanto que tenha acesso à sua conta. Um dos benefícios de usar um serviço de armazenamento em nuvem é que seus dados estão seguros no caso de falha de um dispositivo de armazenamento ou se você enfrentar uma situação extrema, como um incêndio ou roubo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
83

Manutenção de Dados

Como Você Exclui Seus Dados Permanentemente?

- Você já teve que excluir dados ou se livrar de um disco rígido?
- Em caso afirmativo, você tomou alguma precaução para proteger os dados e evitar que caiam em mãos erradas?
- O que você deve fazer para garantir a exclusão de seus arquivos de forma segura e permanente?
  - Para apagar dados, de modo que não sejam mais recuperáveis, eles devem ser substituídos por uns e zeros várias vezes, usando ferramentas projetadas especificamente para fazer exatamente isso.
  - SDelete da Microsoft afirma ter a capacidade de remover completamente arquivos confidenciais.
  - Shred para Linux e Secure Empty Trash para Mac OS X afirmam fornecer um serviço semelhante.
  - A única maneira de garantir que os dados ou arquivos não sejam recuperáveis é destruir fisicamente o disco rígido ou dispositivo de armazenamento.
  - Muitos criminosos se valeram de arquivos considerados impenetráveis ou irrecuperáveis!

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
84

3.3 Quem é o Dono dos Seus Dados?

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Quem é o Dono dos Seus Dados?

Compreensão Dos Termos

- Os Termos de Serviço incluirão algumas seções, desde direitos e responsabilidades do usuário até isenções de responsabilidade e termos de modificação de conta.
- A política de uso de dados descreve como o provedor de serviços coletará, usará e compartilhará seus dados.
- As configurações de privacidade permitem controlar quem vê informações sobre você e quem pode acessar seus dados de perfil ou de conta.
- A política de segurança descreve o que a empresa está fazendo para proteger os dados obtidos de você.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

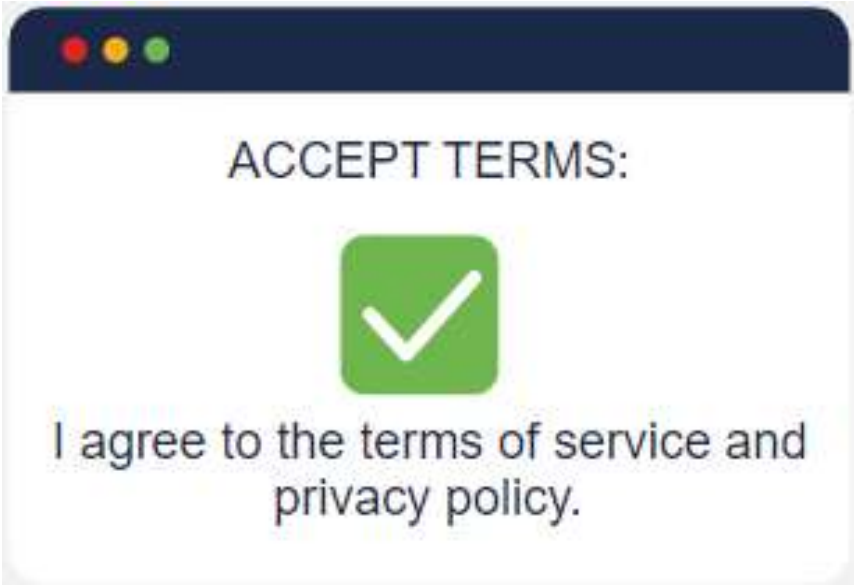
© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
86

Quem é o Dono dos Seus Dados?

O que Você Está Concordando?

- Você criou a conta @Apollo e concordou com os Termos de Serviço da empresa de compartilhamento de fotos on-line.

- Mas você realmente sabe pelo que se inscreveu?



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 87

Quem é o Dono dos Seus Dados?

Antes de se Inscrever

- Quais fatores você deve considerar antes de se inscrever em um serviço on-line?
- Você já leu os Termos de Serviço?
- Quais são os seus direitos em relação aos seus dados?
- Você pode solicitar uma cópia de seus dados?
- O que o provedor pode fazer com os dados dos quais você fez upload?
- O que acontece com seus dados depois que você fecha sua conta?

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
88

3.4 Como Proteger a sua Privacidade on-line

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Como Proteger a Privacidade on-line

Autenticação de Dois Fatores

- Serviços on-line populares, como Google, Facebook, Twitter, LinkedIn, Apple e Microsoft, usam autenticação de dois fatores para adicionar uma camada extra de segurança nos logins de conta.

- Além de seu nome de usuário e senha ou número de identificação pessoal (PIN), a autenticação de dois fatores requer um segundo token para verificar sua identidade.

- Pode ser:
  - objeto físico, como um cartão de crédito, telefone celular ou fob (chave de segurança)
  - varredura biométrica, como impressão digital ou reconhecimento facial e de voz
  - código de verificação enviado por SMS ou e-mail.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Como Proteger a Privacidade on-line

Autorização Aberta ou Open Authorization

- Open authorization (OAuth) é um protocolo padrão aberto que permite que você use suas credenciais para acessar aplicativos de terceiros sem expor sua senha.
- O que isso significa na prática?
- Você está ansioso para se inscrever no curso de segurança da Cisco “Cybersecurity Essentials”, desta série, para ajudá-lo a desenvolver sua carreira. Mas você deve estar conectado ao portal de eLearning para fazer isso.

- Você não consegue se lembrar dos detalhes de login, mas tudo bem. O portal permite que você faça login usando suas credenciais de um site de mídia social como o Facebook ou de outra conta como o Google.

- Portanto, em vez de redefinir seus dados de login, você pode fazer login facilmente no portal de eLearning usando suas contas de mídia social existentes e se inscrever no próximo curso. Você não se aguenta para começar logo!

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
91

Como Proteger a Privacidade on-line

Privacidade de e-mail e Navegador da Web

- Esses problemas podem ser minimizados ativando o modo de navegação privada em seu navegador.
- Muitos dos navegadores mais usados têm seu nome para modo de navegador privado:
  - **Microsoft Internet Explorer:** InPrivate
  - **Google Chrome:** Incognito
  - **Mozilla Firefox:** Private tab or private window
  - **Safari:** Private browsing

- Como funciona o modo privado?
  - Quando o modo privado está ativado, os cookies, arquivos salvos em seu dispositivo para indicar quais sites da Web visitados, são desativados.
  - Portanto, remova todos os arquivos temporários da Internet e exclua seu histórico de navegação ao fechar a janela ou programa.
  - Isso pode ajudar a evitar que outras pessoas coletem informações sobre suas atividades on-line e o incentivem a comprar algo com anúncios direcionados.
  - Mesmo com a navegação privada ativada e os cookies desativados, as empresas estão constantemente a desenvolver novas formas de recolher impressões digitais dos utilizadores para monitorizar o seu comportamento online.

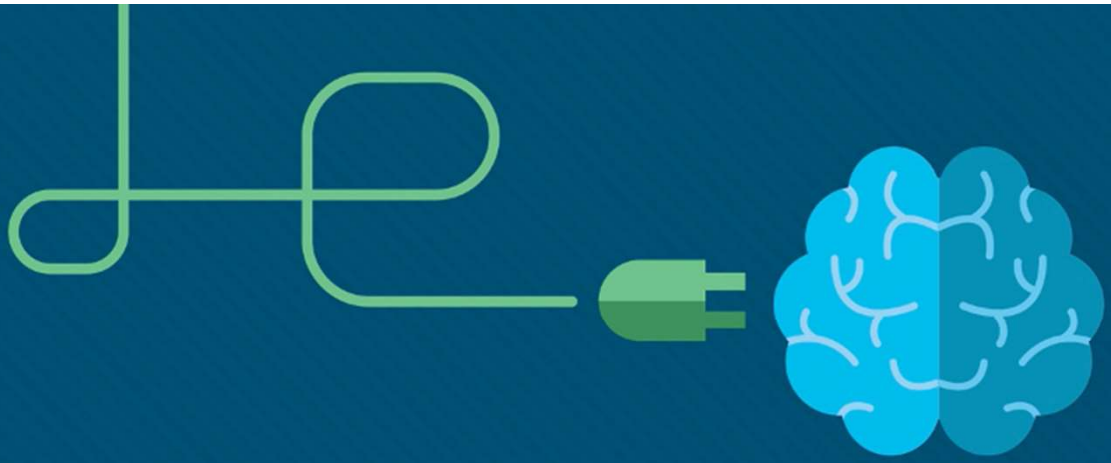
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
92

3.5 Descobrir seu Próprio Comportamento de Risco on-line

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
93



Módulo 4: Protegendo a Organização



Introdução à Cibersegurança

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Objetivos do Módulo

Título do Módulo: Protegendo a Organização

Objetivo do Módulo: Explicar como as empresas podem proteger suas operações contra esses ataques.

Título do Tópico	Objetivo do Tópico
Dispositivos e Tecnologias de Cibersegurança	Explicar os diferentes firewalls, dispositivos de segurança e software usados por profissionais de segurança cibernética que protegem a rede, os dados e os equipamentos de uma empresa.
Abordagem comportamental à segurança cibernética	Explicar como detectar uma ameaça cibernética por meio de abordagens de segurança baseadas em comportamento.
Abordagem da Cisco à segurança cibernética	Explicar a abordagem da Cisco para a segurança cibernética, incluindo a equipe de CSIRT e o manual de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.1 Dispositivos e Tecnologias de Segurança Cibernética

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
96

Dispositivos de Segurança

- Os dispositivos de segurança podem ser dispositivos autônomos, como um roteador ou ferramentas de software executadas em um dispositivo de rede. Eles se enquadram em seis categorias gerais.
  - **Roteadores:** Embora o uso principal de um roteador seja interconectar vários segmentos de rede, eles geralmente fornecem recursos básicos de filtragem de tráfego. Essas informações podem ajudá-lo a definir quais computadores de um determinado segmento de rede podem se comunicar com quais segmentos de rede.
  - **Os firewalls** podem examinar mais profundamente o tráfego da rede para bloquear comportamentos maliciosos. Os firewalls podem ter políticas de segurança sofisticadas aplicadas ao tráfego que passa por eles.
  - **Sistema de prevenção de intrusões**: Os sistemas IPS utilizam um conjunto de assinaturas de tráfego que combinam e bloqueiam tráfego e ataques maliciosos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dispositivos de Segurança (Cont.)

- **Redes privadas virtuais:** os sistemas VPN permitem que funcionários remotos usem um túnel criptografado seguro a partir de seus computadores móveis e se conectem com segurança à rede da organização. Os sistemas de VPN também podem interconectar com segurança filiais com a rede da central.

- **Antimalware or antivirus:** Esses sistemas usam assinaturas ou análises comportamentais das aplicações para identificar e bloquear a execução de códigos mal-intencionados.

- **Other security devices:** Outros dispositivos de segurança incluem dispositivos de segurança para web e e-mail, dispositivos de descriptografia, servidores de controle de acesso de clientes e sistemas de gerenciamento de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 98

Firewalls

- Em redes de computadores, um firewall é projetado para controlar ou filtrar quais comunicações são permitidas dentro e quais são permitidas fora de um dispositivo ou rede. Você pode instalar um firewall em um único computador com o objetivo de proteger aquele computador (firewall baseado em host) ou pode ser um dispositivo de rede autônomo que protege uma rede inteira de computadores e todos os dispositivos host nessa rede (firewall baseado em rede).

- À medida que os ataques a computadores e redes se tornam mais sofisticados, serão desenvolvidos novos tipos de firewalls, que atendem a finalidades diferentes.

    - **Firewall da camada de rede**: filtra as comunicações com base nos endereços IP de origem e destino.

    - **Firewall da camada de transporte:** Filtra as comunicações com base nas portas de dados de origem e destino e nos estados de conexão.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Firewalls (cont.)

- **Firewall da camada de aplicativo:** Filtra as comunicações com base em um aplicativo, programa ou serviço.
- **Firewall de camada sensível ao contexto:** filtra as comunicações com base no usuário, dispositivo, função, tipo de aplicativo e perfil de ameaça
- **Servidor proxy:** filtra solicitações de conteúdo da web como URLs, nomes de domínio e tipos de mídia.
- **Servidor proxy reverso:** colocados na frente dos servidores web, os servidores proxy reversos protegem, ocultam, descarregam e distribuem o acesso aos servidores web.
- **Firewall de tradução de endereço de rede (NAT):** Este firewall oculta ou mascara os endereços privados dos hosts da rede.
- **Firewall baseado em host**: Filtra portas e chamadas de serviço do sistema em um único sistema operacional de computador.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 100

Varredura de Porta

- Na rede, cada aplicativo em execução em um dispositivo recebe um identificador ou número de porta. Este número de porta é usado em ambas as extremidades da transmissão para passar os dados corretos para o aplicativo correto. A varredura de portas investiga um computador, servidor ou outro host de rede em busca de portas abertas. Ele pode ser usado maliciosamente como uma ferramenta de reconhecimento para identificar o sistema operacional e os serviços em execução em um computador ou host, ou pode ser usado de forma inofensiva por um administrador de rede para verificar as políticas de segurança da rede.

- Baixe e inicie uma ferramenta de varredura de portas como Zenmap. Digite o endereço IP do seu computador, escolha um perfil de digitalização padrão e pressione ‘scan’.

- A varredura reportará todos os serviços em execução, como serviços da Web ou de e-mail, e seus números de porta.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
101

Escaneamento de Portas (Cont.)

- A verificação também irá relatar uma das seguintes respostas:
  - ‘Aberto’ ou ‘Aceito’ significa que outros dispositivos de rede podem acessar a porta ou serviço em execução no computador.
  - ‘Fechado’, ‘Negado’ ou ‘Não escutando’ significa que a porta ou serviço não está em execução no computador e, portanto, não pode ser explorado.
  - ´Filtrado’, ‘Descartado’ ou ‘Bloqueado’ significa que um firewall bloqueia o acesso à porta ou serviço e não pode explorá-lo.

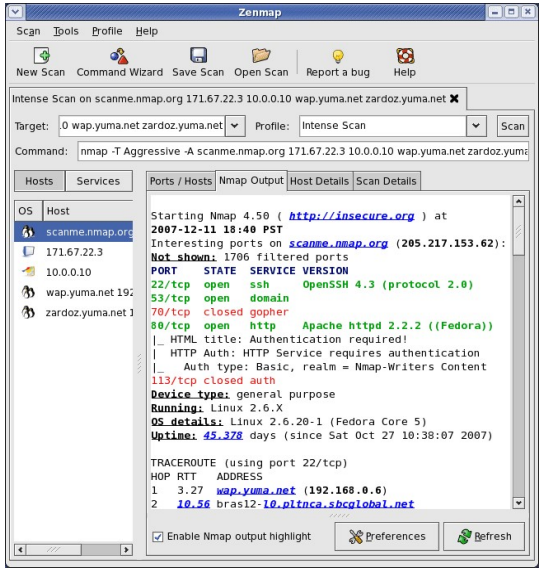


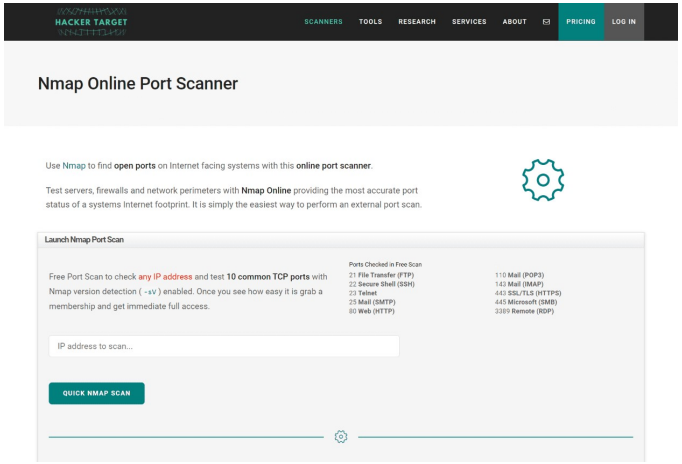
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 102

Escaneamento de Portas (Cont.)

- Para executar uma varredura de porta fora da sua rede, você deve executá-la no firewall ou no endereço IP público do roteador.
- Insira a pergunta "qual é o meu endereço IP?" em um mecanismo de pesquisa como o Google para descobrir essas informações.
- Acesse o Nmap Online Port Scanner, digite seu endereço IP público na caixa de entrada e pressione “Quick Nmap Scan”. Se a resposta estiver aberta para as portas 21, 22, 25, 80, 443 ou 3389, provavelmente o encaminhamento de porta foi habilitado em seu roteador ou firewall e você está executando servidores em sua rede privada.



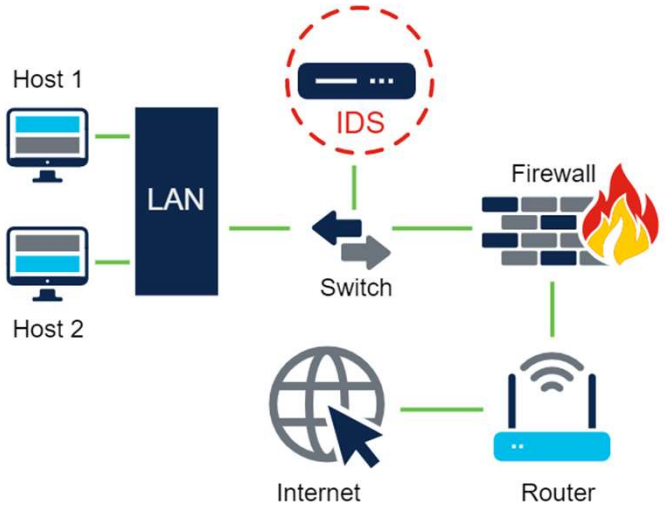


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas de Detecção e Prevenção de Intrusão

- Sistemas de detecção de intrusão (IDSs) e sistemas de prevenção de intrusão (IPSs) são medidas de segurança implantadas em uma rede para detectar e prevenir atividades maliciosas.
- Um IDS pode ser um dispositivo de rede dedicado ou uma das várias ferramentas em um servidor, firewall ou até mesmo um sistema operacional de computador host, como Windows ou Linux, que faz a varredura de dados em um banco de dados de regras ou assinaturas de ataque, em busca de tráfego malicioso.
- Se uma correspondência for detectada, o IDS registrará a detecção de registro e criará um alerta para um administrador de rede. Ela não tomará nenhuma ação e, portanto, não impedirá que os ataques aconteçam. O trabalho do IDS é detectar, registrar e relatar.



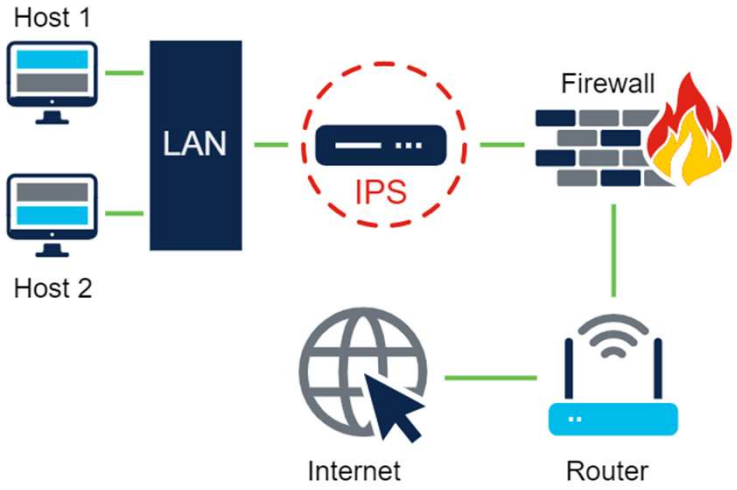
- A varredura realizada pelo IDS deixa a rede mais lenta (conhecido como latência). Colocar um IDS off-line, separado do tráfego normal da rede, evita atrasos na rede. Dados são copiados ou espelhados por um switch e então encaminhados para o IDS para a detecção off-line.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
104

Sistemas de Detecção e Prevenção de Intrusão (Cont.)

- Um IPS pode bloquear ou negar tráfego com base em uma regra positiva ou correspondência de assinatura. Um dos sistemas mais conhecidos de IPS/IDS é o Snort. A versão comercial do Snort é o Sourcefire da Cisco. Sourcefire pode realizar tráfego em tempo real e análise de portas, registro, pesquisa e correspondência de conteúdo, detectar sondagens e ataques e executar varreduras de portas. Ele também se integra a ferramentas de relatórios, desempenho e análise de log de terceiros.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Detecção em Tempo Real

- Muitas organizações hoje não conseguem detectar ataques até dias ou até meses após sua ocorrência.

- A detecção de ataques em tempo real requer uma verificação ativa de ataques usando firewalls e dispositivos de rede IDS/IPS. Ajudaria se você também usasse a detecção de malware de cliente e servidor de última geração com conexões a centros de ameaças globais on-line. Atualmente, os softwares e dispositivos de varredura ativos devem detectar anomalias de rede usando a detecção de comportamento e análise baseada em contexto.

- DDoS é um dos ataques mais potentes que requer detecção e resposta em tempo real. Para muitas organizações, os ataques DDoS prejudicam regularmente os servidores da Internet e a disponibilidade da rede. Esses ataques são extremamente difíceis de se defender porque os ataques se originam de centenas, até mesmo milhares, de hosts zumbis, e os ataques aparecem como tráfego legítimo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteção Contra Malware

- Uma forma de se defender contra ataques de dia zero e ameaças persistentes avançadas (APTs) é usar uma solução empresarial de detecção de malware, como o **Advanced Malware Protection (AMP) Threat Grid** da Cisco.

- Este software cliente/servidor pode ser implementado em endpoints de host, como um servidor independente ou em outros dispositivos de segurança de rede. Ele analisa milhões de arquivos e os correlaciona com centenas de milhões de outros artefatos de malware interpretados em busca de comportamentos que revelam uma APT. Essa abordagem fornece uma visão global de ataques, campanhas e distribuição de malware.

    - **Equipe do Secure Operations Center:** O Threat Grid permite que a equipe do Cisco Secure Operations Center reúna dados mais precisos e acionáveis.
    - **Equipe de resposta a incidentes:** A equipe de resposta a incidentes tem acesso a informações úteis do ponto de vista forense, a partir das quais pode analisar e compreender mais rapidamente comportamentos suspeitos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
107

Proteção Contra Malware (Cont.)

- **Equipe de inteligência de ameaças:** Usando essa análise, a equipe de inteligência de ameaças pode melhorar proativamente a infraestrutura de segurança da organização.
- **Equipe de Engenharia de Infraestrutura de Segurança:** No geral, a equipe de Engenharia de Infraestrutura de Segurança pode consumir e agir com base em informações sobre ameaças com mais rapidez, geralmente de forma automatizada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 108

Melhores Práticas de Segurança

- Muitas empresas e profissionais publicaram listas das melhores práticas de segurança. Você pode encontrar algumas das diretrizes mais úteis em repositórios organizacionais, como o Centro de Recursos de Segurança de Computadores do Instituto Nacional de Padrões e Tecnologia (NIST).
  - **Realize uma avaliação de risco:** Conhecer e compreender o valor daquilo que você está protegendo ajudará a justificar os gastos com segurança.
  - **Crie uma política de segurança:** Descreve claramente as regras, funções, responsabilidades e expectativas dos funcionários da organização.
  - **Medida de segurança física:** Restringir o acesso a armários de rede e locais de servidores e supressão de incêndio.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Melhores Práticas de Segurança de Rede (Cont.)

- **Medidas de segurança de recursos humanos:** A conclusão das verificações de antecedentes deve ser para todos os funcionários.
- **Execute e teste backups:** Faça backup de informações regularmente e teste a recuperação de dados de backups.
- **Mantenha patches e atualizações de segurança:** Atualize regularmente os sistemas operacionais e programas de servidores, clientes e dispositivos de rede.
- **Empregue controles de acesso:** Configure funções de usuário e níveis de privilégio e autenticação forte de usuário.
- **Teste regularmente a resposta a incidentes:** Empregar uma equipe de resposta a incidentes e testar cenários de resposta a emergências.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 110

Melhores Práticas de Segurança de Rede (Cont.)

- **Implemente uma ferramenta de monitoramento, análise e gerenciamento de rede:** Escolha uma solução de monitoramento de segurança que se integre a outras tecnologias.
- **Implemente dispositivos de segurança de rede:** Use roteadores, firewalls e outros dispositivos de segurança da seguinte geração.
- **Implemente uma solução abrangente de segurança de endpoint:** Use software antimalware e antivírus de nível empresarial.
- **Eduque os usuários:** Forneça treinamento aos funcionários em procedimentos de segurança. Uma das empresas mais conhecidas e respeitadas para o treinamento de segurança cibernética é o Instituto SANS. Clique aqui para saber mais sobre SANS e os tipos de treinamento e certificações disponíveis.
- **Criptografar dados:** Criptografe todos os dados organizacionais confidenciais, incluindo e-mail.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 111

4.2 Abordagem Comportamental à Cibersegurança

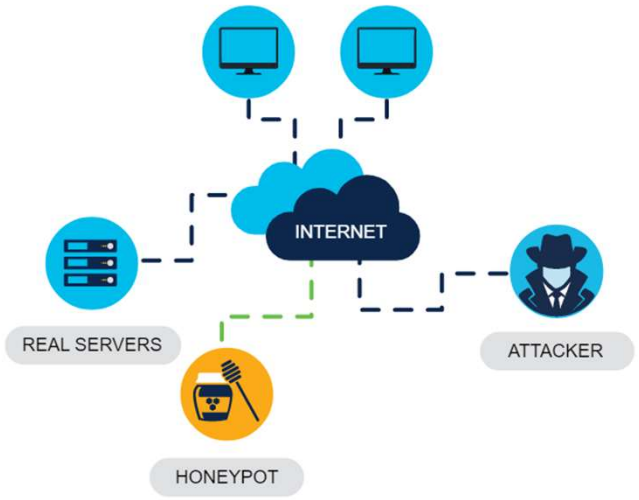
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
112

Abordagem Comportamental à Cibersegurança

Segurança Baseada em Comportamento

- A segurança baseada em comportamento é uma forma de detecção de ameaças que captura e analisa o fluxo de comunicação entre um usuário na rede local e um destino local ou remoto. Quaisquer alterações nos padrões normais de comportamento são consideradas anomalias e podem indicar um ataque.
    - **Honeypots:** Um honeypot é uma ferramenta de detecção baseada em comportamento que atrai invasores apelando para seu padrão previsto de comportamento malicioso. Quando o invasor estiver dentro do honeypot, o administrador de rede poderá capturar, registrar e analisar o comportamento dele para que possa construir uma defesa melhor.



- **Arquitetura de solução de defesa contra ameaças cibernéticas da Cisco:** Essa arquitetura de segurança usa detecção e indicadores baseados em comportamento para fornecer maior visibilidade, contexto e controle. O objetivo é saber quem está realizando o ataque, que ataque está realizando e onde, quando e como o ataque está ocorrendo. Essa arquitetura de segurança usa muitas tecnologias de segurança para atingir esse objetivo.

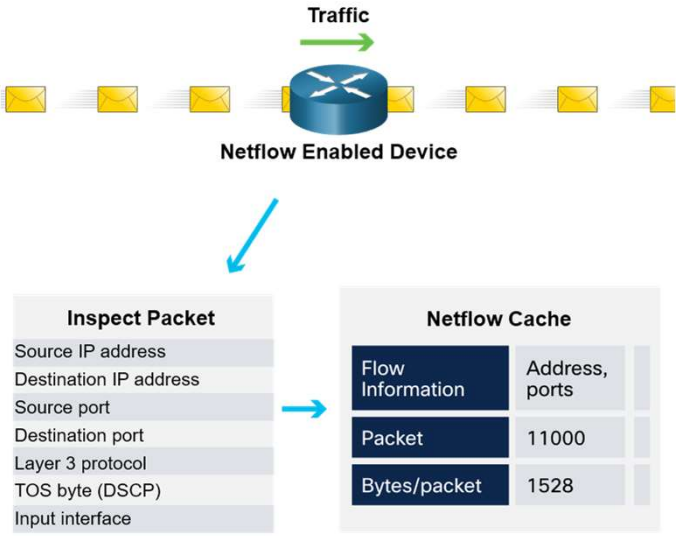
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
113

Abordagem Comportamental à Cibersegurança

NetFlow

- O uso da tecnologia NetFlow visa coletar informações sobre o fluxo de dados através de uma rede, incluindo quem e quais dispositivos estão na rede e quando e como os usuários e dispositivos acessam a rede.
- NetFlow é um componente essencial na detecção e análise baseada em comportamento. Switches, roteadores e firewalls equipados com NetFlow podem relatar informações sobre dados que entram, saem e trafegam pela rede.
- Essas informações são enviadas aos coletores NetFlow que coletam, armazenam e analisam dados do NetFlow para estabelecer comportamentos de linha de base em mais de 90 atributos, como endereço IP de origem e destino.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 114

Abordagem Comportamental à Cibersegurança

Teste de Penetração

- O teste de penetração, comumente conhecido como teste de penetração, avalia um sistema de computador, rede ou organização em busca de vulnerabilidades de segurança. Um pen test busca violar sistemas, pessoas, processos e códigos que possam explorar vulnerabilidades. Estas informações melhoram as defesas do sistema para garantir que ele seja mais capaz de resistir a ataques cibernéticos no futuro.
    - **Passo 1. Planejamento:** O pen tester reúne o máximo de informações possível sobre um sistema ou rede alvo, suas vulnerabilidades potenciais e explorações para usar contra ele. Isto envolve a realização de vigilância passiva ou activa (footprinting) e investigação de vulnerabilidades.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Teste de Penetração (Cont.)

- **Etapa 2: Verificação:** O pen tester realiza reconhecimento ativo para sondar um sistema ou rede alvo e identificar potenciais pontos fracos que, se explorados, poderiam dar acesso a um invasor.

- A vigilância ativa pode incluir:

  - varredura de portas para identificar possíveis pontos de acesso em um sistema de destino
  - verificação de vulnerabilidades para identificar vulnerabilidades potencialmente exploráveis de um alvo específico
  - Ele estabelece uma conexão ativa com um destino (enumeração) para identificar as contas de usuário, sistema e administrador.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 116

Teste de Penetração (Cont.)

- **Etapa 3: Obtendo acesso:** O pen tester tentará obter acesso a um sistema de destino e detectar o tráfego de rede, usando vários métodos para explorar o sistema, incluindo:
  - lançar um exploit com um payload no sistema
  - violar barreiras físicas a ativos
  - engenharia social
  - explorando vulnerabilidades de sites
  - explorando vulnerabilidades ou configurações incorretas de software e hardware
  - Violando a segurança dos controles de acesso
  - Quebrar Wi-Fi com criptografia fraca.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 117

Abordagem Comportamental à Cibersegurança

Teste de Penetração (Cont.)

- **Etapa 4:** Manter o acesso: O pen tester manterá o acesso ao alvo para descobrir quais dados e sistemas estão vulneráveis à exploração. Eles devem permanecer indetectados, normalmente usando backdoors, cavalos de Tróia, rootkits e outros canais secretos para ocultar sua presença.

- Quando essa infraestrutura estiver instalada, o pen tester coletará os dados que considera valiosos.

- **Etapa 5:** Análise e relatórios: O pen tester fornecerá feedback por meio de um relatório recomendando atualizações de produtos, políticas e treinamento para melhorar a segurança de uma organização.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
118

Abordagem Comportamental à Cibersegurança

Redução do Impacto

- Embora a maioria das organizações hoje esteja ciente das ameaças comuns à segurança e faça esforços consideráveis para evitá-las, nenhuma prática de segurança é infalível. Therefore, organizations must prepare to contain the damage if a security breach occurs. E devem agir rápido!
  - **Comunique o problema:** A comunicação cria transparência, o que é fundamental nesta situação.
    - Informar todos os funcionários e comunicar um apelo à ação claro deve ocorrer internamente.
    - A informação a todos os clientes através de comunicação direta e anúncios oficiais deverá ocorrer externamente.
  - **Seja sincero e responsável:** Responda à violação de forma honesta e genuína, assumindo a responsabilidade quando a culpa for da organização.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 119

Redução do Impacto (Cont.)

- **Forneça detalhes:** Esteja aberto e explique por que a violação ocorreu e quais informações foram comprometidas. As organizações geralmente cuidam de quaisquer custos do cliente associados aos serviços de roubo de identidade exigidos como resultado de uma violação de segurança.

- **Encontre a causa:** Tome medidas para entender o que causou e facilitou a violação. Isso pode envolver a contratação de especialistas forenses para pesquisar e descobrir os detalhes.

- **Aplicar as lições aprendidas:** Certifique-se de que todas as lições aprendidas nas investigações forenses sejam aplicadas para evitar a ocorrência de violações semelhantes.

- **Verifique e verifique novamente:** Os invasores geralmente tentam deixar um backdoor para facilitar futuras violações. Para evitar isso, você deve garantir que todos os sistemas estejam limpos, sem backdoors de desinstalação e não comprometam mais nada.

- **Educar:** Conscientizar, treinar e educar funcionários, parceiros e clientes sobre como prevenir futuras violações

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Que é Gestão de Riscos?

- **Gestão de riscos:** O processo formal de identificação e avaliação contínua de riscos para reduzir o impacto de ameaças e vulnerabilidades. Não é possível eliminar o risco, mas é possível determinar níveis aceitáveis ponderando o impacto de uma ameaça com o custo de implementação de controlos para a mitigar. O custo da energia deve ser sempre, no máximo, o valor do recurso que você está protegendo.
    - **Enquadrar o risco:** Identifique as ameaças que aumentam o risco. As ameaças podem incluir processos, produtos, ataques, possíveis falhas ou interrupções de serviços, percepção negativa da reputação de uma organização, possíveis responsabilidades legais ou perda de propriedade intelectual.
    - **Avalie o risco:** Determine a gravidade que cada ameaça representa. Por exemplo, algumas ameaças podem paralisar toda uma organização, enquanto outras podem ser apenas pequenos inconvenientes. Você pode priorizar o risco avaliando o impacto financeiro (uma análise quantitativa) ou o efeito em escala na operação de uma organização (pesquisa qualitativa).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
121

O que é Gestão de Riscos? (Cont.)

- **Responder ao risco:** Desenvolva um plano de ação para reduzir a exposição geral ao risco da organização, detalhando onde o risco pode ser eliminado, mitigado, transferido ou aceito.

- **Monitore o risco:** Revise continuamente qualquer risco reduzido por meio de ações de eliminação, mitigação ou transferência. Lembre-se, você não pode eliminar todos os riscos, então você deve monitorar de perto as ameaças.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 122

4.3 Abordagem da Cisco à Cibersegurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
123

Abordagem da Cisco à Cibersegurança

CSIRT da Cisco

- Muitas empresas de grande porte têm uma equipe de resposta a incidentes de segurança computacional (CSIRT-Computer Security Incident Response Team) para recepção, análise e resposta de incidentes de segurança de computador. O Cisco CSIRT vai um passo além e fornece avaliação proativa de ameaças, planejamento de mitigação, análise de tendências de incidentes e revisão da arquitetura de segurança para evitar a ocorrência de incidentes de segurança.

- O CSIRT da Cisco adota uma abordagem proativa, colaborando com o Fórum de Equipes de Segurança e Resposta a Incidentes (FIRST), o National Safety Information Exchange (NSIE), o Defense Security Information Exchange (DSIE) e o DNS Operations Analysis and Research Center (DNS- OARC). Isso garante que estamos atualizados com os novos desenvolvimentos.

- Várias organizações CSIRT nacionais e públicas, como a Divisão CERT do Instituto de Engenharia de Software da Universidade Carnegie Mellon, estão disponíveis para ajudar organizações e CSIRT nacionais a desenvolver, operar e melhorar as suas capacidades de gestão de incidentes.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Abordagem da Cisco à Cibersegurança

Manual de Segurança

Uma das melhores maneiras de se preparar para uma violação de segurança é evitá-la. As empresas devem orientar sobre o seguinte:

- como identificar os riscos de segurança digital para sistemas, ativos, dados e recursos
- a implementação de proteções e treinamento de pessoal
- um plano de resposta flexível que minimiza o impacto e os danos em caso de violação de segurança
- a colocação de medidas e processos de segurança deve acontecer após uma violação de segurança.

Todas estas informações devem ser compiladas em um manual de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Manual de Segurança (Cont.)

Um manual de segurança é uma coleção de consultas ou relatórios repetíveis que descrevem um processo padronizado de detecção e resposta a incidentes. Idealmente, um manual de segurança deve:

- destacar como identificar e automatizar a resposta a ameaças comuns, como a detecção de máquinas infectadas por malware, atividade de rede suspeita ou tentativas de autenticação irregular
- Descrever e definir claramente o tráfego de entrada e saída
- Fornecer informações resumidas, incluindo tendências, estatísticas e contagens
- Fornecer acesso utilizável e rápido às principais estatísticas e métricas
- Correlacionar eventos em todas as fontes de dados relevantes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 126

Ferramentas para Prevenção e Detecção de Incidentes

Estas são algumas das ferramentas usadas para detectar e prevenir incidentes de segurança:

- Um sistema **Security Information and Event Management (SIEM)** coleta e analisa alertas de segurança, logs e outros dados históricos e em tempo real de dispositivos de segurança na rede para facilitar a detecção precoce de ataques cibernéticos.

- Um sistema de **Data Loss Prevention (DLP)** é projetado para impedir que dados confidenciais sejam roubados ou escapem de uma rede. Ele monitora e protege dados em três estados diferentes: dados em uso (acessando dados por um usuário), dados em movimento (dados viajando pela rede) e dados em repouso (dados armazenados em uma rede ou dispositivo de computador).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

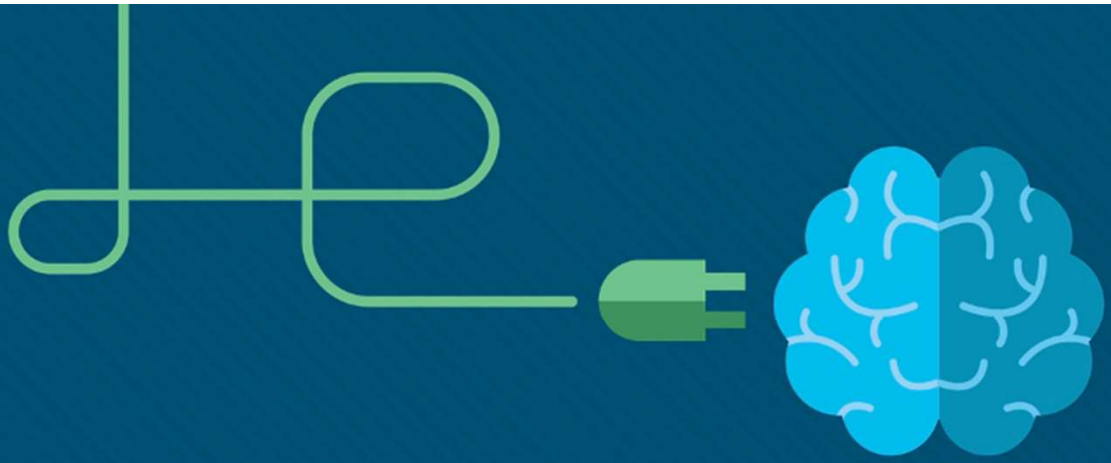
© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
127

Abordagem da Cisco à Cibersegurança

Cisco ISE e TrustSec

O Cisco Identity Services Engine (ISE) e o TrustSec reforçam o acesso do usuário aos recursos de rede ao criar políticas de controle de acesso por função.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Modulo 5: O Seu Futuro Estará na Segurança Cibernética?



Introdução à Cibersegurança

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Objetivos do Módulo

Título do Módulo: Seu Futuro Será na Cibersegurança?

Objetivo do Módulo: Acessar uma variedade de informações e recursos para explorar diferentes opções de carreira em cibersegurança.

Título do Tópico	Objetivo do Tópico
Questões Legais e Éticas	Identificar alguns dos problemas jurídicos pessoais e corporativos que podem surgir ao trabalhar com a segurança cibernética.
Educação e Carreiras	Identificar as certificações profissionais e os próximos passos necessários para seguir uma carreira em segurança cibernética.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
130

5.1 Questões Legais e Éticas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Questões Legais em Cibersegurança

Para se proteger contra ataques, os profissionais de cibersegurança devem ter as mesmas habilidades dos invasores. No entanto, os profissionais de cibersegurança usam suas habilidades dentro dos limites da lei.

Questões jurídicas pessoais

- No trabalho ou em casa, você pode ter a oportunidade e as habilidades de hackear o computador ou a rede de outra pessoa. Mas há um ditado antigo: "Só porque você pode, não significa que você deva". A maioria dos hacks deixa rastros, que podem ser rastreados até você.
- Os profissionais de cibersegurança desenvolvem muitas habilidades, que podem ser usadas de forma positiva ou ilegal. Há sempre uma demanda enorme por aqueles que escolhem usar suas habilidades digitais dentro dos limites legais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 132

Questões Legais em Cibersegurança (Cont.)

Questões legais corporativas

- Empresas e organizações devem obedecer às leis de cibersegurança que a maioria dos países possui.
- A punição por violar leis de cibersegurança enquanto realiza seu trabalho pode ocorrer para a organização; em alguns casos, você pode perder o emprego. Em outros casos, podem acontecer processos, multas e sentenças.
- Se você não tem certeza se uma ação ou comportamento pode ser ilegal, assuma que é ilegal e não o faça. Sempre verifique com o departamento jurídico ou de RH da empresa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 133

Questões Legais em Cibersegurança (Cont.)

Lei Internacional e Cibersegurança

- A lei internacional de cibersegurança é um campo em constante evolução. Os ataques cibernéticos ocorrem no ciberespaço, um espaço eletrônico criado, mantido e de propriedade de entidades públicas e privadas. Não há limites geográficos tradicionais no ciberespaço. Para complicar ainda mais as questões, é muito mais fácil mascarar a fonte de um ataque na guerra cibernética do que na guerra convencional.

- A sociedade global ainda está debatendo a melhor forma de lidar com o ciberespaço. A prática do país, a opinio juris (um entendimento em nome de um país de que está vinculado à lei em questão) e quaisquer tratados redigidos moldarão a legislação internacional de cibersegurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 134

Questões éticas em Cibersegurança

- Pense do teste de penetração que você realizou no @Apollo. Esse teste revelou que um de seus colegas, que começou ao mesmo tempo que você, foi responsável por uma violação de dados. Você está pensando em não incluir isso em seu relatório, pois ele pode ter problemas.

- **Faça a si mesmo as seguintes perguntas para ajudá-lo a decidir sobre a melhor linha de ação.**

  - A ação é lícita?
  - Sua ação está em conformidade com a política da @Apollo ?
  - Sua ação será favorável para a @Apollo e suas partes interessadas?
  - Tudo bem se todos em @Apollo fizerem isso?
  - O resultado de sua ação representaria @Apollo em uma perspectiva positiva em uma manchete?

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Questões Éticas Corporativas

- Muitos profissionais de TI, como a Information Systems Security Association (ISSA) publicaram códigos de ética para ajudar a orientar as ações e os comportamentos dos funcionários.

- A Cisco também tem uma equipe dedicada exclusivamente à conduta ética dos negócios e um Código de Conduta Empresarial para ajudar os funcionários a tomar decisões comerciais e resolver quaisquer problemas que possam surgir.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

5.2 Educação e Carreiras

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Educação e Carreiras

Torne-se um Guru da Cibersegurança

- Você se destacou como Analista de Segurança júnior na @Apollo, mas há muitos empregos em cibersegurança a serem considerados.
- Mesmo que esteja começando sua carreira em cibersegurança, é uma boa ideia consultar motores de busca de empregos, como Indeed, LinkedIn, Monster e CareerBuilder, para ter uma ideia dos empregos disponíveis em todo o mundo!

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
138

Educação e Carreiras

Certificações Profissionais

Certificações em cibersegurança são uma excelente maneira de verificar suas habilidades e conhecimentos, além de impulsionar sua carreira.

- **Microsoft Technology Associate (MTA) Security Fundamentals:** Essa certificação é voltada para alunos do ensino médio e do início da faculdade e para os interessados em uma mudança de carreira.

- **Palo Alto Networks Certified Cybersecurity Associate:** Esta é uma certificação de nível básico para iniciantes que se preparam para iniciar suas carreiras no campo da cibersegurança.

- **ISACA CSX Cybersecurity Fundamentals Certificate:** Esta certificação é voltada para recém-graduados no ensino superior e aqueles interessados em uma mudança de carreira. Este certificado não expira ou requer recertificação periódica.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco
139

Certificações Profissionais (Cont.)

- **CompTIA Security+:** Esta certificação de segurança de nível básico atende aos requisitos da Diretiva 8570.01-M do Departamento de Defesa dos Estados Unidos, sendo um item essencial para quem busca trabalhar em segurança da informação para o governo federal.
- **EC Council Certified Ethical Hacker (CEH):** Esta certificação testa sua compreensão e conhecimento na busca por fraquezas e vulnerabilidades em sistemas-alvo, utilizando o mesmo conhecimento e ferramentas de um hacker malicioso, porém de maneira legal e legítima.
- **ISC2 Certified Information Systems Security Professional (CISSP):** Esta é a certificação de segurança mais reconhecida e popular. Para fazer o exame, você deve ter pelo menos cinco anos de experiência relevante na indústria.
- **Cisco Certified CyberOps Associate:** Esta certificação valida as habilidades necessárias de analistas de cibersegurança de nível associado em centros de operações de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

© 2016 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco 140